A Data-Driven Analysis of Infostealer Malware Victims

Arttu Paju[a,*], Juha Nurmi[a], David Arroyo[b], Sergio Chica Manjarrez[b], Fran Casino[c,d], Mikko Niemelä[e], Juuso Itkonen[f], Joel Scanlan[g], Constantinos Patsakis[h,d], Georgios Smaragdakis[i]

[a]*Tampere University, Tampere, Finland*
[b]*Consejo Superior de Investigaciones Científicas (CSIC), Madrid, Spain*
[c]*Universitat Rovira i Virgili, Tarragona, Spain*
[d]*Athena Research Center, Athens, Greece*
[e]*Cyber Intelligence House, Singapore, Singapore*
[f]*Macquarie University, Sydney, Australia*
[g]*University of Tasmania, Hobart, Australia*
[h]*University of Piraeus, Piraeus, Greece*
[i]*Delft University of Technology, Delft, The Netherlands*

arXiv:2609.30070v1 [cs.CR] 24 Sep 2026

Abstract

Infostealer malware infects devices worldwide and harvests their most sensitive contents: credentials, browser sessions, private keys, and access certificates. Yet its impact on victims remains difficult to study without an ethical, legal, and curated research dataset. To close this gap, we build a privacy-preserving pipeline that turns illicitly sourced infostealer logs into a reproducible research artifact, minimizing sensitive data while preserving measurement utility, and use it to construct a dataset of 170,298 victims from logs of multiple infostealer families. Analyzing these victims, we find that the most compromised services mirror the world's most popular platforms, with gaming and entertainment services strongly overrepresented. Within the sample we identify compromised credentials for high-value organizations, including law-enforcement domains, government and military services, and all eight Ivy League universities, as well as substantial exposure of security-critical infrastructure and of financial, remote-access, and development platforms. Victims also show widespread credential reuse and significant revictimization risk, overlapping with phishing and ransomware victim populations. We release the first anonymized victim-level infostealer dataset under controlled access to enable ethical, privacy-preserving, and reproducible research on information security and victim behavior.

Keywords: Information stealer, Malware-as-a-Service, Credential theft, Web security, Cybercrime measurement, Data anonymization, User behavior

1. Introduction

Recent threat intelligence identifies credential abuse as the top initial access vector, and an analysis of infostealer credential logs found that 30 % of the compromised systems were identified as enterprise-licensed devices [1]. CrowdStrike's latest Global Threat Report estimates that 82 % of modern attacks are executed without malware, with adversaries instead using hands-on-keyboard techniques that blend in with legitimate activity and impede detection; it also reports a 70 % drop in average breakout time between 2021 and 2025, attributed to attackers gaining access to valid accounts [2].

This wealth of valid credentials can be partially attributed to the rise of *infostealers*, a class of malware designed to harvest sensitive information from compromised devices. In 2024, IBM reported a 266 % increase in infostealer deployments and a 71 % increase in valid credential attacks [3]. Infostealer malware collects credentials and personal data, often by exploiting full browser sessions with cookies, rendering strong password policies and multi-factor authentication ineffective [4]. Modern infostealers compromise systems far beyond simple credential theft, exfiltrating private VPN configurations, digital certificates, Secure Shell (SSH) and Pretty Good Privacy (PGP) private keys, authentication tokens, and cryptocurrency wallet keys. This broader data theft enables attackers to bypass security controls, impersonate users, and access internal networks or digital assets, sharply escalating the impact of a compromise. For instance, the 2024 National Public Data (NPD) breach exposed sensitive personally identifiable information (PII) such as full names, Social Security numbers (SSNs), addresses, birth dates, and phone numbers of over 272 million citizens of the US, UK, and Canada [5]. The primary factor in the attack was an infostealer malware infection [4, 6].

While various forms of credential-stealing malware have existed for years, dozens of infostealer families have recently emerged, offered under the Malware-as-a-Service (MaaS) model [7] through various platforms, significantly lowering the technical barrier for cybercrime operators. In this context, after purchasing malware control software, the adversary typically convinces victims (i.e., usually through social engineering) to download and execute malicious binaries. Prior research has shown that some infostealer logs are available online, even though some sources are difficult to locate and access [8].

*Corresponding author.
Email address: arttu.paju@tuni.fi (Arttu Paju)

Table 1: Research questions, their scope, and how they are answered.

#	Research question	Scope	Answered
RQ1	How can large-scale analysis of illicitly sourced infostealer logs be conducted and shared in ways that minimize harm, protect privacy, and support reproducible research?	While data anonymization can significantly impact data utility, we extract many insights about the victims of infostealers by using a minimized and anonymized set, providing a step-by-step methodology that can be replicated to analyze similar datasets and share the data with the community for further research.	Section 3, Appendix A, Data availability
RQ2	What tooling, techniques, and infrastructure do modern infostealers use to harvest and exfiltrate credential-rich logs?	We discuss the methods used to infiltrate hosts and the tactics, techniques, and procedures used after the analysis of thousands of samples of specific infostealer families. Additionally, we illustrate their infrastructure and C2 servers.	Section 4
RQ3	Who are the victims in the anonymized logs, what do their online behavior and credential practices reveal, and are they susceptible to other digital scams?	We characterize victim representativeness, geography, operating systems, and the service categories of victims' stored credentials. We then explore username and password practices and investigate whether victims have fallen for phishing attacks and to what extent recent ransomware victim organizations have leaked credentials.	Section 5.1, Section 5.2, Section 5.3, Section 5.4, Section 6
RQ4	How often do infostealer logs harvest credentials associated with security critical systems like government, military, law enforcement, and critical infrastructure operators?	We analyze the collected logs to identify logs associated with mission critical systems, focusing on organizations that, if compromised, may have detrimental and cascading effects.	Section 5.5, Section 5.6
RQ5	What are the illegal activities of infostealer victims that can be inferred from the leaked logs?	Beyond reporting victims' service preferences, we identify domains directly linked to various forms of illegal activity.	Section 5.7
RQ6	How exposed are victims' high-value commercial services, such as financial and communication platforms?	We quantify victims' exposed credentials for financial services and for communication and privacy-oriented platforms.	Section 5.8, Section 5.9

This paper complements previous studies on password stealers [9] by focusing on victims' characteristics and behavior. Industry reporting draws on proprietary data that cannot be independently reproduced [2, 3], and academic work has largely examined the malware itself, the stolen-data markets, and their economics rather than the victims behind the logs [7, 8, 10]. This research gap is consequential: the logs expose not just individuals but the organizations they belong to, from critical infrastructure to government services, and defenders cannot prioritize a risk they cannot measure.

We conduct a large-scale, data-driven analysis of the victims of modern infostealer malware. We collect the logs from archives advertised as RedLine, Raccoon, Vidar Stealer, LummaC2, MetaStealer, StealC, Rhadamanthys and Atomic macOS Stealer, some of which also bundle logs of unknown origin, so each label describes an archive rather than any individual record. To process them, we develop a legally and ethically approved methodology that removes direct personally identifiable information while retaining analytical value and reducing residual re-identification risk. We then analyze the anonymized data for insights into the victims and their exposure, paying particular attention to the behavioral-analysis and impersonation risks [10] that persist even in an anonymized dataset derived from infostealer logs.

We constructed our dataset, which we share with the research community, from 170,298 distinct victims worldwide, compromised in 2024–2025 and collected in January 2025. We study the representativeness of our sample and find that, while it overrepresents an online gaming population, it still spans a broad, global demographic.

Building on this dataset, we examine not only infection demographics and exposed credentials but also victim interests, organizational exposure, revictimization trends, and evidence of illegal or deviant behavior. We find that cybercriminals themselves are sometimes infected, which enables us to study their illicit activity, and that infostealers reach mission-critical infrastructure and services to a notable extent. We summarize our research questions in Table 1.

Our contributions can be summarized as follows:
(i) a data-driven analysis of infostealer victims and their exposure, to our knowledge the first at this scale to study victims through openly shared logs rather than the malware or the markets that sell it;
(ii) a methodology for the legally and ethically compliant investigation of infostealers; and
(iii) an analysis framework and the first anonymized victim-level infostealer dataset released for reproducible research.

Section 2 and Section 3 cover background and methodology, and Section 4 characterizes infostealer tooling and infrastructure. Section 5 reports our findings on the victims and their exposure, Section 6 examines their exposure to other forms of cybercrime, and Section 7 interprets the findings, states our limitations, and draws lessons for defense.

2. Background and related work

Infostealer malware extracts sensitive data from infected devices and sends it to attacker-controlled infrastructure. Infostealers are often sold as MaaS, allowing even unskilled actors to run credential theft campaigns [7]. They target browser-stored data, including credentials, cookies, and payment card information, but also extract VPN configurations, cryptocurrency wallets, and sometimes even gaming or messaging tokens. For example, Rhadamanthys can extract data from browsers, VPN/email clients, password managers (e.g., KeePass), and crypto wallets [11]. Similarly, Lumma has specific modules for exfiltrating device data [12].

Once active on a victim's machine, infostealers aggregate stolen data into log files. Initially, the preferred exfiltration method was an HTTP POST to hardcoded C2 servers. More recently, many families have moved to Telegram bots [13], cloud application programming interfaces (APIs), and abused services like Pastebin or GitHub to evade detection, channels also seen in the samples we analyze (Table 4). The resulting logs, often tagged with a unique "bot ID," form a highly lucrative dataset for attackers. Moreover, operators may manually filter high-value credentials, such as VPNs or banking logins, for resale on underground markets.

Campaigns distributing infostealers typically rely on affiliates (also called "traffers"), who use phishing [14], malvertising,

Search Engine Optimization (SEO) poisoning, and trojanized installers to infect systems [7, 9]. Social platforms like TikTok and YouTube are also exploited through so-called "ClickFix" scams, which masquerade as beneficial videos offering quick fixes to common tech issues, yet deliver malware [15]. Newer delivery tactics include fake CAPTCHAs, where a hijacked page asks visitors to prove they are human by pasting a command that the page has already copied to their clipboard, which runs PowerShell to fetch the payload. A related trick packages the malware as a malicious dynamic-link library (DLL) beside a legitimate signed executable that side-loads it, so the bundle only appears benign [16]. More targeted lures also appear, such as malware disguised as a fake "checker", a tool marketed to other criminals that claims to test lists of stolen credentials against a service and report which accounts still work. Reported cases pose as an OnlyFans checker (LummaC2) or a Netflix checker (RedLine) [17, 18]. There are also reports of infostealers embedded in browser extensions and malicious mobile apps [19]. This diverse set of infection approaches has led to massive infection counts. For instance, Microsoft observed that the LummaC2 alone had over 394,000 global Windows infections in a two-month span in early 2025 [20]. Notably, infostealers are not only targeting home users: enterprise employees are also targeted, since corporate credentials (for VPNs, Single Sign-On accounts, etc.) can yield much higher value [21].

In the past, stolen credentials were traded mostly on hacking forums or dark web marketplaces in a "piecemeal" fashion. The notorious *Genesis Market* (2018–2023) exemplified this model, selling "browser fingerprints" and account credentials from malware logs [8]. Genesis allowed buyers to purchase a victim's entire identity package (login cookies, saved passwords, and OS details) to bypass multifactor authentication and fraud detection by perfectly mimicking the victim's device. With the rise of specialized log markets and Telegram channels, this trade has become far more streamlined. Telegram now serves both as an advertising hub for infostealer services and a marketplace where, for a subscription fee, buyers can download large volumes of fresh logs without purchasing each victim's data individually (see Figure C.1 in Appendix C). Its popularity stems from ease of use, anonymity, and the ability to broadcast instantly to large audiences.

2.1. Comparison with prior work

Previous infostealer studies have focused primarily on specific ecosystems or narrower datasets. For example, Nurmi et al. [8] characterized the Genesis Market and its trading model but did not analyze victim-level credential data at scale. Patsakis et al. [7] surveyed the MaaS landscape and categorized infostealer families, offering a technical taxonomy but lacking a large-scale empirical measurement of victim logs.

The closest prior work to our study is Avgetidis et al. [9]. For 20 months (April 2019 to December 2020), using a dataset built from tracking pixels embedded in decoy credentials, they followed 4,586 stealer operator devices and 5,295 command-and-control (C2) server panels (web interfaces on C2 servers where logs are exfiltrated) across 10 malware families. They reported potential infections inside the networks of the U.S. Social Security Administration, the U.S. House of Representatives, and the U.S. Senate. Their focus was the attacker's side, the operator devices and panel infrastructure. The present study focuses on the victims and uses the stolen logs to quantify exposure of credentials and other information.

Detection work aimed specifically at infostealers is sparse. Buescher et al. [22] detected credential theft at runtime from inside the browser, and Bustos-Tabernero et al. [23] classified infostealer variants with graph neural networks. Behavioral profiling is more commonly done for malware in general, with ATT&CK serving as the vocabulary for describing what a sample does when executed [24]. We do not propose a detector; Section 4 characterizes what seven families do once they run.

Industry reports from IBM [3], CrowdStrike [2], and others provide threat intelligence based on proprietary data, which cannot be independently verified or reproduced. Marjanov and Hutchings [10] examined the risks associated with behavioral analysis from infostealer logs but focused on re-identification rather than broad victim characterization. Our work differs from these studies in three key aspects: (i) we provide a large-scale, multi-family measurement (170,298 victims) from a single time window, enabling cross-family technical and infrastructural comparisons; (ii) we release an anonymized dataset and analysis scripts for full reproducibility, unlike proprietary industry reports; and (iii) we examine not only technical indicators but also victim behavior, institutional exposure, revictimization, and digital hygiene, bridging the gap between threat intelligence and empirical security measurement. The sensitivity of this data demands a rigorous methodology that preserves victim privacy, which we present in the next section.

3. Methodology

The scale of the infostealer ecosystem demands a privacy-first approach to studying victimization and organizational risk. To address RQ1 and enable the rest of our analysis, we designed the pipeline in Figure 1 to acquire, sanitize, and analyze infostealer malware data exfiltrated from victim devices. This pipeline received approval from the Ethics Advisory Board of the SafeHorizon project (see Appendix A).

3.1. Data collection methodology

In 2024, we crawled 404 underground forums on Tor and the clear web. These forums originated from an existing large-scale threat intelligence collection maintained by Cyber Intelligence House, where analysts had verified each forum as having hosted, advertised, or repeatedly linked to infostealer malware logs or related marketplaces. We continuously crawled these forums to discover invitations to external communication channels, which led us to monitor 53 Discord and Telegram channels that actively shared infostealer malware logs during January 2025. These logs contained infostealer malware victim data from 2024 to 2025. Each record carries a single date, the date the log was collected. The source logs record neither when a stealer produced them nor when they were first published, so the generation and publication periods cannot be recovered from our data. 42 of

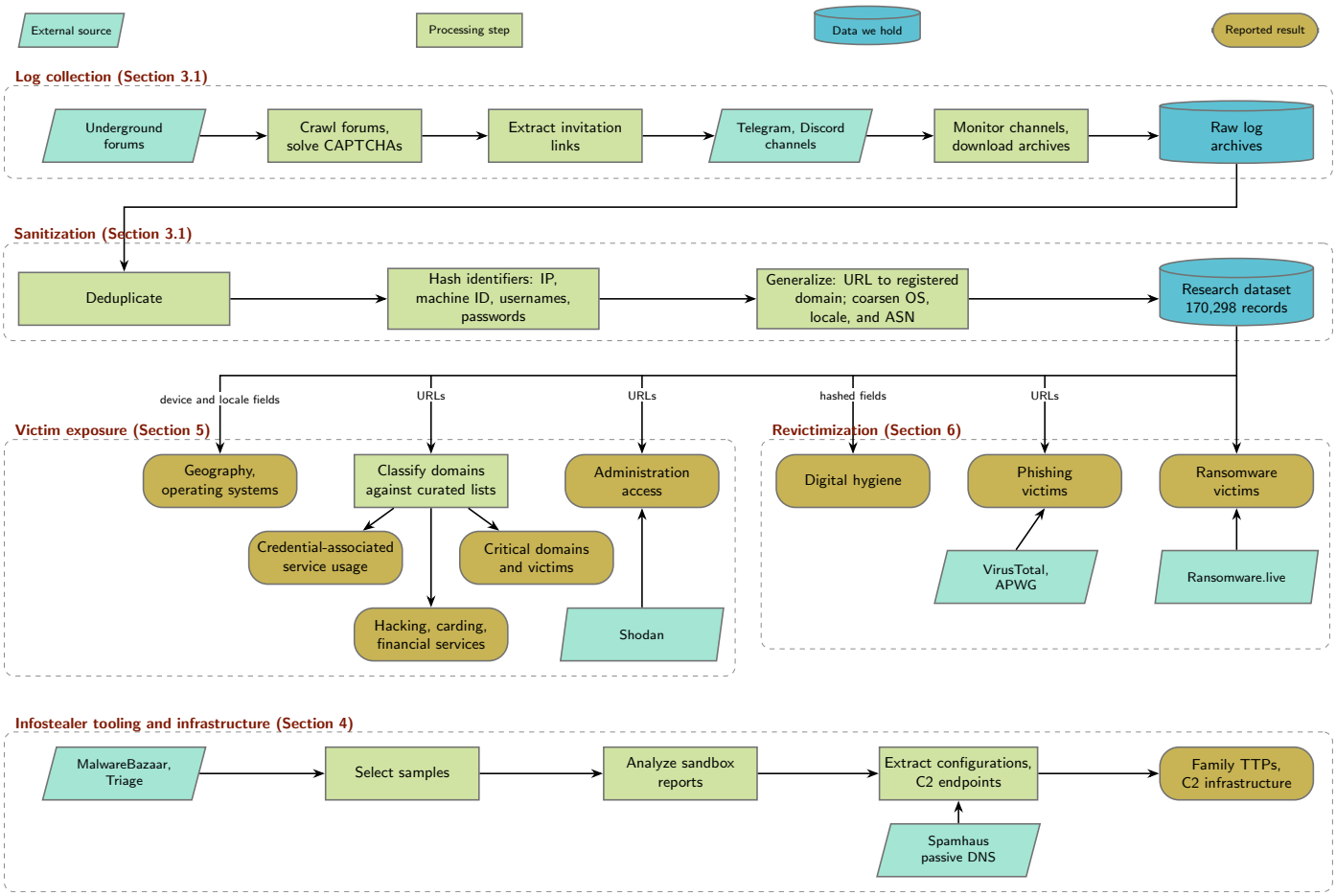


Figure 1: Pipeline of our methodology, from acquiring malware logs from illicit sources to the analyses each section reports.

the monitored channels were hosted on Telegram, with the remaining 11 channels on Discord. The channels covered multiple languages, primarily English, Russian, Ukrainian, and Chinese, although additional languages were also observed. Most Telegram channels were publicly accessible through invitation links, while a smaller subset required private invitations. Table 2 reports how the logs in our dataset are distributed over the archives we collected them from. Each label is the family the archive was advertised as, not an attribution of the individual records it holds. The dataset contains records from eight advertised families, but individual records carry no family label; family-level analysis is therefore performed only on the malware samples (Section 4), not on the victim records.

We collect data through a fully automated, iterative pipeline designed for reproducibility and minimal manual bias:

1. Forum crawling: Dedicated crawlers continuously collect text from the manually curated underground forums on both the clear web and Tor to detect indicators of infostealer activity, including malware promotion, advertisements for leaked logs, configuration leaks, and shared malware log archives. These crawlers solve CAPTCHAs and authenticate themselves in forums to collect website text content.

2. Telegram and Discord communities: Pattern-matching algorithms automatically identify invitation links to Telegram and Discord communities together with references to emerging channels connected to infostealer ecosystems. Newly discovered channels are manually verified before being incorporated into the monitoring pipeline.

3. Telegram and Discord monitoring: Automated bots join the verified data leak groups to maintain situational awareness and collect newly published data sources. Some channels were dedicated almost exclusively to distributing infostealer malware logs, often on a daily or weekly basis, whereas others shared malware logs only occasionally alongside broader discussions of leaked databases, credential dumps, and other cybercrime-

Table 2: Collected logs per archive, labelled by the family the archive was advertised as. "Collection" rows bundle multiple sources.

Family	Logs	Usernames	Passwords
LummaC2	97,509	17,158,285	17,210,301
Collection: Unknown, Atomic macOS Stealer, and Rhadamanthys	59,336	9,203,402	9,525,152
Vidar Stealer	5,978	556,058	557,580
StealC	5,630	484,189	511,119
Collection: Raccoon, LummaC2, MetaStealer, and StealC	1,625	185,558	186,171
RedLine	168	24,190	24,207
Collection logs: MetaStealer and StealC	52	10,023	12,159
Total	170,298	27,621,705	28,026,689

related content.

4. Infostealer malware log collection: Infostealer malware network operators share data for free (i.e., for advertisement purposes, see Figure C.1 in Appendix C) both in messenger groups and on the underground forums. When malware log archives or related files are detected, they are programmatically downloaded into a secure analysis environment. These raw datasets are then subjected to a controlled preprocessing phase.

5. Processing research datasets: Finally, we extracted and minimized the data to create a curated research dataset. We removed direct personal identifiers while retaining the necessary behavioral and technical indicators for the analysis. We replaced victims' IP addresses, usernames, passwords, and hardware identifiers by hashing each value with a long random salt. We used the same salt for all logs during a single processing run, so identical input values produced identical identifiers throughout the dataset, which allowed us to align records across logs. For example, in the example entry in Appendix D, the same usernames output the same value, "b8f2935589." We did not retain the original values or the salt value; thus, the identifiers cannot be reversed to recover the original values.

The URL field recorded which services each victim had authenticated to, and its path, query, and fragment carried account identifiers, session tokens, and the structure of private endpoints. We therefore reduced every URL to its registered domain, keeping only the `http://` or `https://` prefix and discarding any embedded credentials, the port, the path, the query, and the fragment, so that `https://login.example.com/user?token=abc` became `https://example.com`. Keeping the prefix preserves whether the victim reached the service over an encrypted connection. Raw IP addresses and internal host names have no registered domain, so we kept the host itself for those.

After removing the direct identifiers, we generalized the data further, because a combination of operating system, language, keyboard layouts, VPN status, and autonomous system could identify a victim even though none of these fields identify anyone on its own. We treated these five fields as quasi-identifiers and generalized them in two steps, leaving VPN status unchanged throughout, because an aggregate label would have stated something untrue about the victim. First, we replaced every value that appeared in fewer than 100 records with an aggregate label. Second, we enforced k-anonymity with $k = 5$: we counted the occurrences of every combination of the five fields, and for each combination occurring in fewer than five records we replaced further values with the aggregate label until at least five records shared the combination. We replaced the values in a fixed order, starting with the autonomous system, then the keyboard layouts, the operating system, and finally the language. The released dataset contains 3,470 distinct combinations of the five fields, each shared by at least five records.

Table 3 lists the content, the disclosure risk, and the treatment of every field in a released record. We did not generalize country information, because it is the unit of analysis for the geographic results in Section 5. Including it among the five fields above would have left 5.30 % of records in combinations occurring fewer than five times, a residual re-identification risk that the controlled access described in Appendix A addresses.

This structured approach supports compliance with the legal and ethical constraints on using illicitly sourced data [25, 26]; Appendix A discusses how we balance the benefits and risks for victims, organizations, security practitioners, and society. Although we analyze only anonymized data and not the full logs, the pipeline (Figure 1) enables us to curate and study the dataset more systematically than current industry reports.

Figure 1 traces this pipeline end to end. It begins with the underground-forum and Telegram and Discord log collection described above. The resulting logs are deduplicated, minimized, and anonymized into the research dataset, which the victim analyses of Section 5 and Section 6 then study. We also characterize the malware behind these logs (Section 4), drawing on the sample records and sandbox reports published by `MalwareBazaar` and `Triage`, and extracting their configurations and C2 infrastructure.

3.2. Dataset representativeness and bias characterization

Our dataset is derived from infostealer logs and does not constitute a random sample of the global internet population. Instead, it reflects the victims whose devices were compromised by specific infostealer campaigns and whose logs were subsequently shared online. Within each victim's logs we observe only the services the victim authenticated to with stored credentials, so we do not see the full browsing history and miss any site visited without logging in (Section 7.1). To characterize the dataset, we compare the prevalence of widely used services in our dataset with global usage statistics and compute the infection rate per country. The dataset is skewed toward a highly active online gaming population, pointing to the infection method for infostealer distribution (e.g., via cheats, mods, or pirated software).

We show that the dataset provides broad geographic coverage and captures a security-relevant online gamer subpopulation. It is therefore suitable for studying credential compromise, victim behavior, and organizational exposure within this segment. Future work can reduce bias by integrating additional data sources (e.g., incident response datasets, enterprise telemetry, or multiple log-sharing ecosystems).

After removing duplicates and victims without compromised services, we study a sample of distinct victims (N = 170,298). These victims possess unique machine identifiers or distinct IP addresses and at least one compromised service. The macOS victims lack machine identifiers; consequently, we compare their IP addresses. Each of these victims is one record in the released dataset, and throughout this article one record is one victim: every count we report is a count of records rather than of devices or of people. The mapping is not exact, since a device on a dynamic address can appear as more than one record, while a shared address, a VPN exit point or a public machine can merge several devices into one. We bound this effect for the macOS victims in Section 7.1.

4. Infostealer tooling and infrastructure

Before turning to the victims, we characterize the malware behind these logs, working from samples rather than from the

Table 3: Field-level treatment of the released victim records. Direct identifiers were replaced by salted hashes, URLs were reduced to their registered domain, and the quasi-identifiers were generalized to prevent re-identification.

Field	Content	Disclosure risk	Treatment in the released dataset
`ip_address`	Victim IP address	Direct identifier	Salted hash
`machineid`	Hardware identifier	Direct identifier	Salted hash
`usernames`, `passwords`	Credentials for the compromised services	Direct identifiers; usernames frequently contain real names	Salted hash; no recoverable credential material remains
`urls`	Services the victim authenticated to	Paths and query strings carry account identifiers, session tokens, and the internal structure of private endpoints	Reduced to `http(s)://registered-domain`; credentials, port, path, query, and fragment are dropped
`onion_domain_names`	Tor services the victim reached	As above	Host names only, as collected
`ip_asn`	Autonomous system and its operator	A small network can identify an employer, a campus, or a single subscriber	Kept for the 275 systems seen in at least 100 records, which covers 63.95 % of victims; the rest read "ASN: aggregated"
`os`	Operating system	The build number narrows the population sharply	Edition kept, build number and architecture removed
`language`	Locale of the compromised host	The region subtag is often rare	Reduced to the language subtag, so "es-UY" becomes "es"
`keyboard_layouts`	Keyboard layouts installed on the host	Multilingual layout sets are close to unique	Reduced to layout language names, so "English (India)" becomes "English"
`location`	City and region derived from the IP	Near unique in combination with the fields above	Removed
`is_vpn`	Whether the IP belongs to a VPN provider	Two values, low on its own	Kept
`country`, `ip_location`	ISO-2 country code	Coarse on its own	Kept; the unit of analysis for the geographic results
`timestamp`	Date the log was collected	Narrows the infection window	Kept; the source logs carry no time of day
`*_count`	Number of URLs, usernames, and passwords	Aggregate	Kept, and unchanged by the treatments above

logs themselves: how seven of the eight families named in Table 2 operate and the infrastructure that supports them. Samples for Atomic macOS Stealer were not available. Once launched, an infostealer harvests sensitive data from installed browsers (passwords, cookies, and session tokens), cryptocurrency wallets, communication platforms, gaming credentials, payment methods, local accounts, and email, and it may log keystrokes, capture screenshots, and read the clipboard. These capabilities let attackers bypass authentication and exfiltrate highly sensitive data, causing serious business, financial, or personal harm.

Method: To characterize the infostealer families and address RQ2, we studied the behavior of infostealer samples covering seven of these families, drawing on the records and sandbox reports published by MalwareBazaar [27] and Triage [28]. The executions, the family labels, and the mapping from observed behavior to MITRE ATT&CK techniques [29] are those services' own. The sample and variant counts in Table 4 cover 389,562 samples. The technique rankings in its last column come from an earlier extraction of 59,451 of these samples, and we therefore report the ten techniques each family triggers most often as an ordering rather than as counts. We then identified the families' command and control (C2) servers and mapped where their infrastructure is hosted, extracting IP addresses where they were directly used and resolving historical addresses through Spamhaus' passive DNS API [30]. We excluded abused benign services such as `pastebin.com`, `telegram.org`, `steamcommunity.com`, and `raw.githubusercontent.com`.

Results: The tactics, techniques, and procedures (TTPs) that dominate across all families are system-oriented: T1614.001 (System Language Discovery), T1012 (Query Registry), T1082 (System Information Discovery), and T1005 (Data from Local System) rank among the most common, reflecting infostealers' reliance on system data access and discovery.

The families differ most in what they do around collection. Persistence ranks in the top ten for RedLine, Raccoon and StealC, through registry run keys (T1060, T1547.001), scheduled tasks (T1053) and service creation (T1543.003), and RedLine alone ranks disabling security tools (T1089). LummaC2, Vidar and Rhadamanthys stay within discovery and collection, consistent with a single run that exfiltrates and exits. Virtualization and sandbox checks (T1497) rank high only for LummaC2, StealC and Rhadamanthys, all first seen in 2022 or 2023. Two families stand apart: Rhadamanthys is the only one to rank email collection (T1114), matching its targeting of mail and VPN clients [11], and MetaStealer's ranks are dominated by installer and script execution (T1546.016, T1218.007, T1059.001) together with permission changes (T1222), reflecting delivery through trojanized installer packages. The mapping mixes current and superseded ATT&CK identifiers, so Raccoon ranks both T1130 and T1553.004, and RedLine both T1060 and T1547.001, for what is the same behavior.

For C2, some families used domain generation algorithms [31, 32] or private Telegram channels, and some share common infrastructure (Figure E.1 in Appendix E). MetaStealer's algorithm, for instance, draws from a pool of about 60,000 `.xyz` domains. Passive DNS shows which families resolved to an address, not who leased it, so this is overlap in hosting rather than evidence about operators. In total, the hosting infrastructure spans 7,401 unique IP addresses (125 IPv6; Figure 2), reflecting the industrialized scale of MaaS operations.

5. Analysis of infostealer victims and their exposure

The methodology of Section 3 produced an anonymized dataset we can study without exposing victims. We use it first to

Table 4: Platforms, discovery date, and the ten most common TTPs of the seven infostealer families we obtained samples for, in decreasing order of frequency. The sample and variant counts cover 389,562 samples; the TTP rankings were computed over an earlier extraction of 59,451 of them.

Family	Platforms	First Seen	Variants	Samples	# Observed C2s	C2 types	TTPs (MITRE ATT&CK categorization [29])
LummaC2	Windows/macOS	August 2022	8,636	34,971	6,180	Abuse of benign domains and services: `pastebin.com` 77 `.xyz` domains, 1,224 `.shop` domains, 1,203 `.top`, 128 `.icu`	T1614.001, T1012, T1082, T1497, T1112, T1005, T1552.001, T1553.004, T1217, T1555.003
MetaStealer	Windows/macOS	March 2023	6	103	n/a	DGA candidate space of 60,000 `.xyz` domains, not observed endpoints	T1082, T1614.001, T1012, T1120, T1222, T1546.016, T1218.007, T1059.001, T1005, T1552.001
Raccoon	Windows	April 2019	1,073	6,362	579	7 unique domains, no benign. 4 `.com`, 1 `.ink`, 1 `.xyz`, 1 .site	T1112, T1012, T1005, T1081, T1130, T1082, T1553.004, T1120, T1060, T1053
RedLine	Windows	March 2020	7,732	287,103	3,293	Abuse of benign domains and services: `duckdns.org`, `ddns.net`, `pastebin.com`, `ngrok.io`, Telegram (`t.me`), 163 `.xyz` domains, 69 `.top` domains, 11 `.shop` domains	T1005, T1012, T1081, T1082, T1112, T1060, T1053, T1031, T1089, T1547.001
Rhadamanthys	Windows	December 2022	259	1,432	158	15 unique domains, no benign. 1 `.asia`, 3 `.xyz`, 1 `.nl`, 1 .site, 2 `.online`, 1 `.shop`, 2 `.ug`, 3 `.com`, 1 `.ug`, 1 `.net`	T1082, T1012, T1614.001, T1114, T1120, T1497, T1005, T1112, T1081, T1059.001
StealC	Windows	January 2023	968	32,864	553	Abuse of benign domains and services: Telegram (`t.me`) and `steamcommunity.com` 3 `.xyz` domains, 28 `.top` domains	T1082, T1012, T1614.001, T1497, T1005, T1552.001, T1112, T1120, T1547.001, T1543.003
Vidar Stealer	Windows	October 2018	2,244	26,727	272	Abuse of benign domains and services: (`tumblr.com`), GitHub (`github.com` and `githubusercontent.com`), `steamcommunity.com`, `tiktok.com`, `ultimate-guitar.com`, Telegram (`t.me`), `mastodon.social`, 15 `.xyz` domains	T1082, T1012, T1112, T1005, T1614.001, T1552.001, T1553.004, T1217, T1555.003, T1081

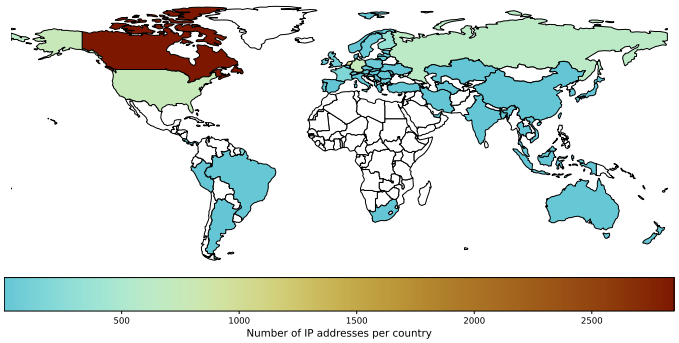


Figure 2: Infostealer C2 Infrastructure (partial). Map lines delineate study areas and do not necessarily depict accepted national boundaries; this applies to all maps in this paper.

characterize the victims themselves, and then to measure what their compromise exposes: the organizations whose credentials they hold, their own illegal activity, and their high-value personal services.

5.1. Representativeness

Our logs cover only the people who were infected, not internet users at large, so any conclusion we draw rests on knowing who those victims are. Characterizing them is the first half of RQ3. The dataset reaches victims in all major countries (Section 5.2); here we begin by asking whether the services they use match the wider online population.

Method: We compare how often popular domains appear among victims against publicly available global usage statistics.

Results: The most frequently compromised services prove to be the globally most-used online services. We compute the main domains from the compromised services and the share of victims holding credentials for each (see Table 5). Every one of these top 40 domains is held by more than 5 % of victims, including roughly half who hold Facebook (Meta) and Google credentials (Gmail users authenticate to Google).

Table 6 shows each domain's prevalence among victims against its global usage: the share of victims holding credentials, the estimated global usage of the service (as a percentage and in millions of monthly active users), and the relative difference between the two.

Table 5: The top 40 domains from the compromised services and the percentage of victims with credentials to these services.

Domain	%	Domain	%
google.com	64.04	github.com	10.14
facebook.com	51.30	openai.com	9.77
live.com	46.93	yahoo.com	9.30
discord.com	30.02	zoom.us	8.99
instagram.com	29.46	rockstargames.com	8.44
roblox.com	28.61	tlauncher.org	8.10
netflix.com	25.96	sony.com	7.38
amazon.com	20.49	adobe.com	6.76
steampowered.com	19.39	ubisoft.com	6.48
twitter.com x.com	18.12	nexusmods.com	6.17
paypal.com	16.96	localhost	6.13
spotify.com	16.20	tiktok.com	6.10
microsoftonline.com	16.17	samsung.com	5.93
twitch.tv	15.99	battle.net	5.57
apple.com	15.98	ea.com	5.46
epicgames.com	14.56	xiaomi.com	5.39
riotgames.com	13.97	snapchat.com	5.36
mega.nz	12.57	aliexpress.com	5.18
steamcommunity.com	11.97	disneyplus.com	5.16
linkedin.com	11.38	aternos.org	5.11

Table 6: Comparison of domain prevalence in infostealer data (%) vs. global usage (% and millions), and the infostealer victim data relative difference (%).

Domain	Victims	Global usage	Difference
google.com (gmail)	64.04 %	44.96 % (2,500 [33])	+42 %
facebook.com	51.30 %	55.13 % (3,065 [34])	-7 %
instagram.com	29.46 %	35.97 % (2,000 [35])	-18 %
discord.com	30.02 %	3.60 % (200 [36])	+734 %
roblox.com	28.61 %	6.83 % (380 [37])	+319 %
netflix.com	25.96 %	5.43 % (302 [38])	+378 %
amazon.com	20.49 %	5.58 % (310 [39])	+267 %
steampowered.com	19.39 %	2.37 % (132 [40])	+718 %
twitter.com x.com	18.12 %	11.98 % (666 [41])	+51 %
paypal.com	16.96 %	7.81 % (434 [42])	+117 %
spotify.com	16.20 %	12.14 % (675 [43])	+33 %

The victim sample and the global usage metrics do not rep-

resent the same sample space, so Table 6 is descriptive context rather than a statistical comparison. The relative differences (such as +734 % for Discord or +718 % for Steam) indicate empirical overrepresentation within the population affected by infostealers, rather than a formal deviation from a homogeneous probabilistic distribution, and reflect exposure to risk associated with specific digital behaviors such as gaming and youth communication platforms. The higher number of accounts for these services among victims indicates that infostealers might spread through the typical behaviors of gaming communities, which prior work has analyzed [44, 45]. URLs containing the keyword "cheat" reach more than 8,500 victims with credentials for video game cheat sites such as *lavicheats* or *skycheats*. Plausible vectors include pirated game mods, cheat software, unofficial game launchers, and social engineering on gamer-focused platforms like Discord.

Takeaway 1. *The most compromised services mirror the world's most popular platforms, yet gaming and entertainment services (Discord, Roblox, Netflix, Steam) are massively overrepresented, possibly pointing to game-related infection vectors such as cheats and pirated mods.*

5.2. Geographic distribution

Method: We compare the number of infections to the number of internet users in each country. As of early 2025, approximately 5.56 billion people worldwide are internet users, accounting for 68.7 % of the global population [46].

Results: Of the 170,298 victims, 164,163 carry country information derived from their IP addresses, and we observe victims from all major countries (see Figure 3). Normalizing by internet population, the highest per-capita infection rates concentrate across Asia, Africa, Latin America, and Eastern Europe. Among countries with at least 100 victims, Mongolia has the highest rate (260 infections, 356.54 per million internet users), followed by Trinidad and Tobago (230 infections, 217.24 per million), and Togo (198 infections, 205.44 per million). At the other extreme, Russia's 335 infections equate to only 2.58 per million. Eritrea, Tajikistan, Turkmenistan, and North Korea show no infections.

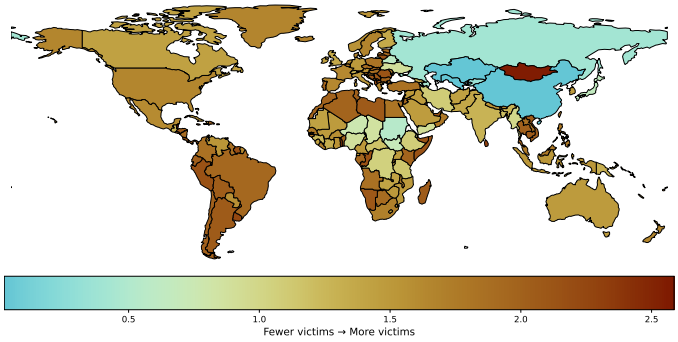


Figure 3: The number of victims per country per million internet users is calculated using a base-10 logarithmic scale.

The volume of leaked credentials also varies sharply across countries. Each victim discloses, on average, 147.09 tuples of URL, username, and password, but Figure 4 shows large differences between countries. These differences largely follow the reach of individual campaigns. Russian cybercriminals, for example, run a large-scale ecosystem [47] built on infostealers such as Lumma; because these tools spread mainly through Russian-speaking forums and are run by regional developers [48, 49], their campaigns stay geographically concentrated, which in turn shapes who their victims are. A few hosts leak far more credentials than the rest: 70 hosts exceed 10,000 tuples, two orders of magnitude above the average, and the largest single leak holds 157,107 tuples. These outliers are most likely shared machines in public places such as libraries or airports, where many people save their credentials on the same device.

Table 7: Operating systems used by the victims.

Operating system	Count	%	Operating system	Count	%
Win 10 Pro	65,519	38.47	Windows 11	4,848	2.85
Win 11 Home	27,096	15.91	Win 10 Enterprise	4,807	2.82
Win 11 Pro	22,606	13.27	macOS	4,523	2.66
Win 10 Home	20,735	12.18	Windows 10	1,755	1.03
Unknown	10,122	5.94	Win 7 Ultimate	1,041	0.61
Other	6,281	3.69	Windows 8	965	0.57

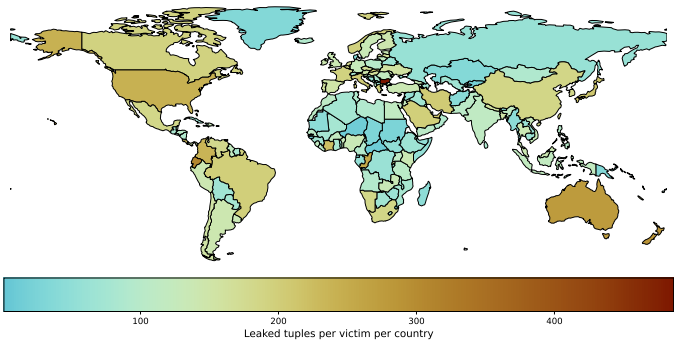


Figure 4: Average leaks per victim per country.

Takeaway 2. *Per-capita infection rates vary widely across countries and are highest across Asia, Africa, Latin America, and Eastern Europe. The number of credentials leaked per victim follows the reach of individual campaigns.*

5.3. Operating systems

Method: We tabulate the operating system reported in each victim's log, standardizing names across build numbers and language variants and omitting architecture, since almost all systems are 64-bit.

Results: Table 7 shows the operating systems the victims run. Windows dominates, and only a minimal fraction of victims (≈ 1.37 %) run deprecated systems such as Windows 7 and 8 that no longer receive official security updates [50]; macOS accounts for 4,523 victims (2.66 %). The logs record the operating system release, not its patch level, so these counts show which releases victims run but not how current those installations were kept. Section 5.10 compares the victims of the two platforms.

Takeaway 3. *Victims overwhelmingly run current, supported operating system releases, so no platform is safe from infection.*

Whether unpatched systems are over-represented is a separate question our data cannot answer.

5.4. Victims' credential-associated service usage

We identify 322 victims authenticated to more than 500 unique domains (hosting one or more services), a sign of infrequent password clean-up, a very long browsing history, or other practices that leave them vulnerable to credential theft. This section asks what types of service the credentials stolen from these victims belong to.

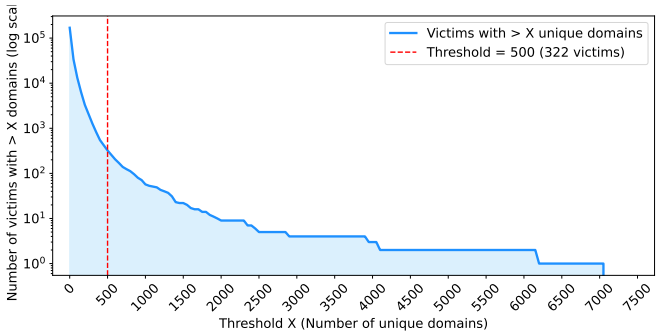


Figure 5: Number of victims with strictly more than X unique domains, plotted on a logarithmic scale. The red dashed line marks the analytical threshold of ≥ 500 unique domains ($n = 322$ victims).

Method:

Using the Cisco Talos API [51], we reduce each URL where a victim stored credentials to its registered domain and assign that domain to one of Talos's 106 domain categories. We focus on two groups of categories: those identifying recreational, personal, risky or illicit activities (Table 8), and those indicating institutional or professional activities ("Government and Law", "Health and Medicine", "Education", and "Finance").

Besides focusing on victims with more than 500 domains, we retain only domain categories with at least 200 victims, corresponding to 42 categories, and analyze how these categories co-occur in victims' credential logs. For each victim we normalize the number of domains in each category by that victim's total number of domains. We reduce the resulting victim-by-category matrices via SVD. We retain the smallest number of components whose cumulative explained variance reaches 85 %, capturing the dominant structure while discarding noise. The number of dimensions selected is $k = 4$. Finally, we compute the cosine similarity between the category columns (see Figure 6).

Table 8: List of categories associated with recreational, personal, risky or illicit services.

Illegal downloads	Gambling	Pornography
Weapons	Illegal drugs	Cannabis
Cheating & plagiarism	Filter avoidance	Hate speech
Cryptomining	Extreme	Illegal activities
Adult	Online Trading	Alcohol
Terrorism & violent extremism	Child sexual abuse material	Hacking

Results: Among these victims, deviant activities intersect directly with professional and work-related services on the same machine (Figure 6).

Specifically, we observe a strong alignment among institutional and professional usage: "Government and Law" and "Health and Medicine" exhibit an extremely high correlation (0.98), grouping closely with "Education" via robust correlations of 0.71 and 0.82, respectively. Notably, "Finance" and "Pornography" show an exceptionally strong correlation of 0.98 with each other, while both keep moderate positive correlations with institutional sectors: "Pornography" correlates 0.62 with "Government and Law" and 0.44 with "Health and Medicine", and "Finance" 0.53 and 0.35 with the same two categories. Furthermore, "Illegal Downloads" maintains unexpectedly strong positive correlations with these core institutional categories (0.77 with "Government and Law", 0.79 with "Health and Medicine", and 0.86 with "Education"), rather than standing apart as an isolated high-risk cluster. Conversely, "Online Trading" shows weak negative correlations with institutional sectors (−0.29 with "Government and Law" and −0.30 with "Health and Medicine"), while "Gambling" is essentially uncorrelated with them (0.06 and −0.01). The presence of this dual usage demonstrates a critical intersection of risk, where infostealer infections capture victims who combine personal or recreational risk behaviors with critical professional activity, making the leaked credentials exceptionally sensitive.

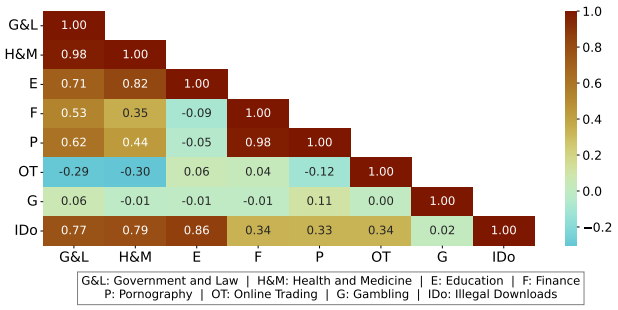


Figure 6: Cosine similarity between the categories of credential-associated service usage, under strict filtering (> 500 domains per victim, ≥ 200 victims per category; $n = 322$ victims).

Takeaway 4. *Analyzing victims with negligent credential retention practices reveals an overlapping exposure vector: personal and recreational activities intersect directly with professional services on the same machines, indicating that victims engaged in high-risk behaviors also store credentials for institutional services, rendering the leaked data highly sensitive.*

5.5. Critical domains and victims

RQ4 asks how often infostealers reach security-critical and other high-profile organizations.

Method: We searched for victims who had authenticated to specific high-value domains, taking the eight Ivy League universities (Brown, Columbia, Cornell, Dartmouth, Harvard, Pennsylvania, Princeton, and Yale) as an example of well-known institutions, alongside security- and privacy-focused organizations and government bodies. Table 9 groups these domains by

the kind of organization that runs them, keeping commercial services separate from institutions whose members are affiliated with them. These are illustrative cases rather than a representative sample of affected organizations; the global spread of infections is reported in Section 5.2.

Results: This search surfaces compromised credentials across all eight Ivy League universities; technology and security-relevant organizations including `torproject.org` and `linuxfoundation.org` (Table 9); and both `interpol.int` and `dhs.gov` (United States Department of Homeland Security) together with 32 other police domains.

Table 9: Analyzing anecdotal evidence: compromised credentials for high-profile services, grouped by the kind of organization that runs the domain.

Domain	Count	Domain	Count
Universities and research institutes			
mit.edu	4,158	yale.edu	35
harvard.edu	129	ox.ac.uk	29
stanford.edu	118	columbia.edu	28
berkeley.edu	88	mpg.de	27
cornell.edu	70	uchicago.edu	17
upenn.edu	63	princeton.edu	10
cam.ac.uk	48	brown.edu	6
cmu.edu	35	dartmouth.edu	3
Scholarly publishers and preprint servers			
springernature.com	82	arxiv.org	22
nature.com	50	biorxiv.org	2
Professional and standards bodies			
ieee.org	448	usenix.org	1
acm.org	53		
Open-source and privacy foundations			
linuxfoundation.org	19	torproject.org	2
gnu.org	2		
Commercial services			
openai.com	16,641	sans.org	49
Government and law enforcement			
dhs.gov	42	interpol.int	2

Many of the compromised services suggest that misuse of the harvested credentials could enable access to sensitive organizational resources. In particular, compromised organizational email accounts may serve as an entry point to broader systems by enabling password reset mechanisms across connected services. Table 10 provides illustrative examples of such compromised domains. Following responsible-disclosure practice, we report these at the registered-domain level rather than naming the exact endpoints that were reached; the released dataset applies the same reduction. Unauthorized access to such infrastructure may have serious implications for institutional integrity, confidentiality, and the continuity of operations.

Takeaway 5. *Stolen credentials reach highly sensitive organizations, including all eight Ivy League universities, government and military portals, Interpol, and more than 30 police forces, any of which could give attackers a foothold inside the institution.*

Table 10: Examples of compromised sensitive organizational domains.

Domain	Description
`army.mil.ph`	Philippine Army, email system
`prefecturanaval.gov.ar`	Argentine Naval server
`tni-au.mil.id`	Indonesian Air Force Academy
`osd.mil`	U.S. Department of Defense
`army.mil`	U.S. Army login and authentication portals
`crmforce.mil`	The U.S. Air Force Academy
`tavanir.org.ir`	Iranian electric grid company
`who.int`	WHO intranet and webmail systems
`navy.mil.ph`	Philippine Navy email server
`boeing.com`	Boeing secure login platform
`af.mil`	U.S. Air Force personnel and engineering portals
`jaf.mil.jo`	Jordanian Armed Forces email server

5.6. IP addresses and administration access

The data contains login information for well-known platforms accessed via standard domain names, but victims also authenticated directly via IP addresses (e.g., `https://x.x.x.x/admin/`), which often points to private systems such as admin panels or development environments, as well as to domains on non-public top-level domains used only within private networks or VPN infrastructures. The logs also capture more than passwords: private VPN configurations, digital certificates, SSH and PGP private keys, and other authentication tokens. An adversary holding such credentials and URLs could pivot across systems along three vectors: bypassing security controls to impersonate users and enable lateral movement, privilege escalation, and persistence; authenticating directly to an IP address to reach non-public systems; and authenticating to remote-access services (e.g., TeamViewer) or developer platforms to seize full control of a host or entry into development pipelines and cloud environments. The recent compromise of Ingram Micro [52] shows how costly exposed VPN access to critical infrastructure can be.

Method: We compile every entry where a victim authenticated directly to an IP address and geolocate those we can. For these hosts we query Shodan for open ports, running services, operating systems, and known vulnerabilities, which an adversary could use to compromise them further (see Table 11). We also identify credentials for remote-access and developer-oriented services, and we extract the domains that use internal-only top-level domains (TLDs).

Results: Turning these vectors into measurements, we find that victims authenticated to 50,219 direct IP addresses; of these, 38,760 could be geolocated and are mapped in Figure 7. Some of these services require multi-factor authentication, e.g., `github.com`; however, since the victim's system is compromised, an adversary could extract the necessary cookies and authenticate, bypassing the multi-factor authentication. Also, we find leaked access to popular software development services, including `github.com`, `aws.amazon.com`, `teamviewer.com`, and `docker.com`. Beyond that, we identify domains that do not use standard or publicly accepted TLDs, but instead rely on internal TLDs such as `.local`, `.lan`, and similar. In total, we extract 4,385 such domains, counting each domain once regardless of how many victims reached it and excluding `.onion` addresses, which are Tor services rather than internal hosts. Examples include

addresses like `http://army.lan`. Many of these domains appear to reference internal administrative interfaces, databases, or corporate services intended for employee access within closed organizational environments.

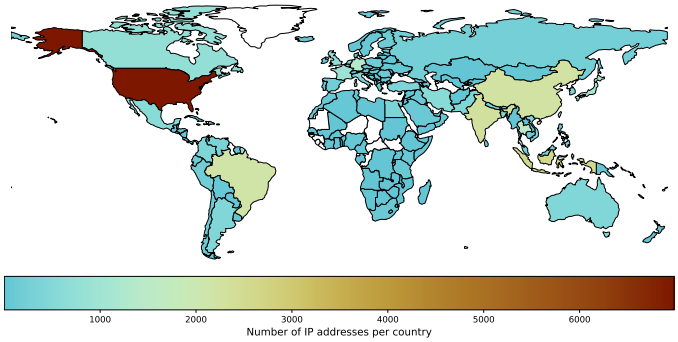


Figure 7: Direct IP addresses victims have authenticated per country.

From the 38,760 external IPs, we found 13,162 scanned by Shodan. The operating system and open ports statistics are provided in Table 11b and Table 11a, respectively. Because victims accessed these systems through a browser, most of the systems expose a common port used by a web server, e.g., 80, 443, and 8080; however, other ports commonly used by SSH (port 22, n = 4,256) and File Transfer Protocol (FTP, port 21, n = 1,199), along with MySQL (port 3306, n = 1,048) and Remote Desktop Protocol (RDP, port 3389, n = 852), are also exposed. Additionally, Shodan reports known vulnerabilities for many of these systems, whose Common Vulnerability Scoring System (CVSS) score distribution is illustrated in Figure 8, implying that many of these systems are potentially exposed to severe threats.

Table 11: Shodan statistics.

(a) Most common ports.

Port	Count	Port	Count
80	7,088	53	1,165
443	5,526	3306	1,048
22	4,256	2000	959
8080	1,231	3389	852
21	1,199	161	750

(b) Most common operating systems.

Operating system	Count
Linux	1,197
Windows	995
Ubuntu	597
Windows Server 2022 (build 10.0.20348)	89
Windows (build 10.0.17763)	64
Debian	64
Windows (build 10.0.14393)	56
Windows (build 6.3.9600)	42
Windows Server 2012 R2 (build 6.3.9600)	40
Windows (build 10.0.19041)	37

Moreover, there are 1,233 URLs with leaked credentials pointing to intranet services, 122 of which belong to `gov` domains. Likewise, there are 484 leaked credentials to governmental mail services.

Takeaway 6. *Beyond website logins, victims stored credentials for 50,219 IP-addressed hosts and 4,385 internal-only domains, including admin panels and exposed SSH, RDP, and database services that an adversary could use to pivot into internal networks.*

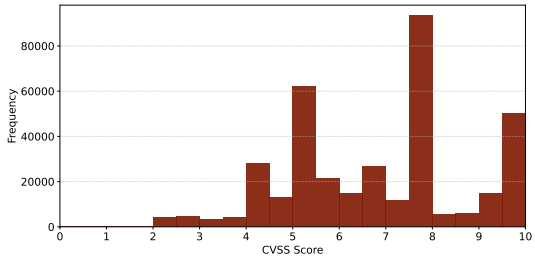


Figure 8: CVSS distribution of vulnerabilities.

5.7. Hacking and carding

So far we have treated victims purely as targets. To address RQ5, we examine the illegal activity that can be inferred from the logs, asking whether some victims appear to be involved in cybercrime themselves.

Method: Carding forums are online communities dedicated to trading stolen payment-card data and associated fraud services, whereas hacking forums trade exploits, compromised accounts, and other offensive cyber services. While crawling the 404 forums introduced in Section 3.1, we found that 205 of them, such as `cardforum.cc`, hosted carding and hacking material behind a login. We used this sublist of 205 forums to count how many infostealer victims authenticated into carding and hacking communities.

The Tor Browser enables users to access anonymous onion websites. Infostealer malware captures this usage data, providing us with a mechanism to study those who have authenticated into anonymous onion websites on Tor. We analyze victims who have authenticated to at least one onion website using a Tor Browser.

Results: We identify 850 victims who authenticated to at least one carding or hacking forum site. A further 188 victims authenticated to onion sites on Tor, commonly to illegal marketplaces. The geographic distribution of the carding and hacking forum victims is shown in Figure 9. While it does not demonstrate a large population, it does show the ability to identify risky and possibly illicit activities within the dataset.

Takeaway 7. *A small subset of victims appear to be involved in cybercrime themselves: 850 authenticated to carding and hacking forums and 188 to Tor onion sites, commonly illegal marketplaces.*

5.8. Financial service exposure

RQ6 asks how exposed victims' high-value commercial services are. We begin with financial platforms, where a compromised credential translates most directly into monetary loss. Financial harm can also arrive indirectly, for example when a payment card linked to a Google, Amazon, or Apple account

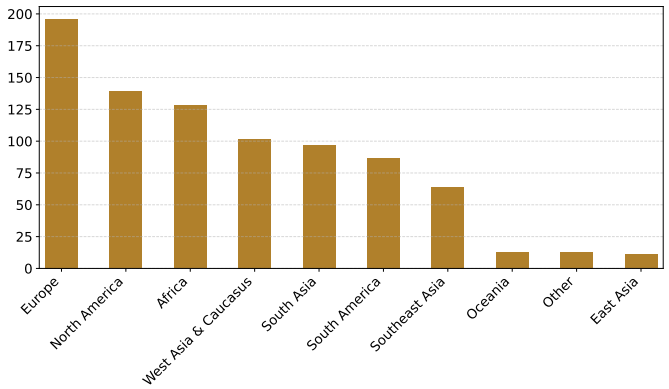


Figure 9: Region-specific breakdown of hacking and carding forum victims.

enables an adversary to make unauthorized purchases, but this indirect impact is hard to quantify.

Method: A victim is financially exposed if the logs hold a credential for a domain where an account keeps or moves money. We used the public API of the Federal Deposit Insurance Corporation (FDIC) [53] and the bank membership list of the Euro Banking Association [54] to assemble a list of 4,221 bank domains. We took payment processors, exchanges, brokerages, and mining pools from the Talos categorization introduced in Section 5.4, using its Finance, Cryptocurrency, Online Trading, and Cryptomining categories. The two sources give 31,414 financial domains in total, every one of them holding a balance or a payment instrument that a stolen credential can reach. We report how many victims hold at least one such credential and how many distinct financial domains each stored.

Results: Infostealers collected financial credentials from 73,782 victims, 43.33 % of the dataset, who stored on average 4.84 distinct financial domains each. Table 12 lists the 20 domains held by the most victims. The exposure sits with payment and cryptocurrency services rather than with banks. PayPal alone accounts for 39.1 % of affected victims, while only 4,152, or 2.44 % of the dataset, hold a credential for any of the 4,221 bank domains. The two bank sources cover only US and European institutions, so banks elsewhere reach the analysis through the Talos categorization instead, `caixa.gov.br`, `hdfcbank.com`, and `nubank.com.br` among them. Because the bank list is regional, the 2.44 % is a lower bound on bank exposure rather than a global rate, though it remains an order of magnitude below the payment platforms. This suggests that despite the wide adoption of e-banking, victims infrequently store their credentials for banking domains. In the case of European financial institutions, this could reflect the stringent authentication requirements established by the European Union's second Payment Services Directive (PSD2) [55]. As underlined by infostealer attacks, impersonation is a critical matter for e-payments, and for this reason PSD2 is currently being updated in part to address spoofing attacks in the context of a proposed PSD3.

Takeaway 8. *Infostealers exposed financial credentials for 73,782 victims, 43.33 % of the dataset, concentrated in payment platforms (led by PayPal) and cryptocurrency services rather than traditional banks, which reach only 2.44 %. The pattern tracks authentication strength: banks enforce regulated strong authentication such as PSD2, so the exposure shifts to payment and crypto services that often do not, where browser-stored credentials leave accounts directly at risk.*

Table 12: The 20 financial domains held by the most victims. Each victim is counted once per domain, so a victim with accounts at several of them appears in several rows.

Domain	Victims	Domain	Victims
paypal.com	28,876	iqoption.com	1,550
binance.com	5,867	onlinesbi.sbi	1,386
coinbase.com	4,062	olymptrade.com	1,346
caixa.gov.br	3,907	hdfcbank.com	1,338
payoneer.com	3,146	sandbox.game	1,319
nicehash.com	2,235	qxbroker.com	1,280
paysafecard.com	2,095	blockchain.com	1,256
exness.com	2,004	faucetpay.io	1,242
stripe.com	1,868	intuit.com	1,149
wise.com	1,728	nubank.com.br	1,090

5.9. Communication and privacy-oriented services

The other commercial category under RQ6 is communication and privacy: victims also expose the collaboration platforms they use for work and the services they rely on to protect their privacy.

Method: We compare communication and privacy-oriented services in our dataset, including both mainstream collaboration platforms and privacy-focused alternatives. For mainstream platforms, we search for Zoom, Webex, and Slack as widely used enterprise collaboration tools. For privacy-focused services, we search `tuta.com` and `tutanota.com` (Tuta Mail), `proton.me` and `protonmail.com` (Proton Mail), and VPN services. This comparison allows us to assess the relative prevalence of privacy-oriented services among infostealer victims.

Results: Zoom (n = 11,422), Webex (n = 1,275), and Slack (n = 932) are common collaboration services in the dataset. Proton Mail appears in 1,963 victim profiles (1.15 % of our sample). For comparison, Proton reports approximately 100 million accounts worldwide[1], representing roughly 1.80 % of the global internet user base [46]. The similar privacy-driven email service Tuta is considerably less popular (n = 177). Furthermore, if we seek the pattern "VPN" in the list of accessed URLs, we can identify victims using a VPN service (n = 9,929), with particular relevance for those using services such as ProtonVPN, NordVPN, or SurfSharkVPN, as these VPN services are categorized as privacy-respectful [56].

Takeaway 9. *Privacy tooling is not enough on its own to avoid infostealers. Users of privacy-focused email and VPNs appear among victims, suggesting these services offer limited protection against infection, which is unsurprising given that infostealers compromise the endpoint rather than the network.*

These results collectively reveal an intersection of risk: infostealer infections indiscriminately capture a large global population (Section 5.2, Section 5.3), yet the resulting data facili-

[1] https://proton.me/blog/proton-100-million-accounts

tates future targeted attacks against critical infrastructure (Section 5.6), law enforcement and other sensitive institutions (Section 5.5), and financial services (Section 5.8). Gaming and entertainment services are strongly overrepresented among victims (Section 5.1), who demonstrate weak baseline security practices across both personal and professional domains (Section 5.4, Section 6.2).

5.10. Differences between macOS and Windows victims

Method: Our logs carry no infostealer family label for individual victims, because the attribution in Table 2 applies to a collection of logs rather than to a single record. The operating system still separates the families, since a macOS host cannot have been infected by the Windows-only families and Atomic macOS Stealer reaches no Windows host, so comparing the two platforms is the closest our data gets to comparing families. Separately for the 4,523 macOS and the 151,161 Windows victims, we recompute the median number of domains a victim stored credentials for, the share of victims holding credentials in the deviant and institutional category groups of Section 5.4, the share reaching a direct IP address or an internal TLD (Section 5.6), and the password reuse rate of Section 6.2. We add one group, workplace categories that credentials reach more often through work than through personal use: Organizational Email, SaaS and B2B, Online Meetings, Business and Industry, and Professional Networking. Every measurement except the medians is the percentage of victims who stored credentials for at least one domain of that kind, or who reused at least one password. We count all victims of each platform, not only the 322 who authenticated to more than 500 domains in Section 5.4. Percentages carry Wilson score intervals and the medians percentile bootstrap intervals. The macOS victims live in different countries and store more credentials than the Windows victims, and either difference could produce a gap on its own. We therefore group the victims by country, by how many domains they stored, and by both together, take the macOS percentage inside each group, and average those percentages using the Windows group sizes as weights. The result is the percentage the macOS victims would show if they were spread over the groups like the Windows victims (direct standardization).

Results: Every measurement holds on both platforms in the same order, but the magnitudes differ (Table 13). The macOS victims stored credentials for more domains, were more exposed on institutional, financial and workplace services, and were about twice as likely to store credentials for an internal host, yet they reused passwords less often. None of the three adjustments moves a macOS percentage by more than 4.9 points, so neither geography nor the volume of stored credentials accounts for these differences. The deviant category moves the most, and its gap to Windows narrows to 2.7 points.

Takeaway 10. *Every finding holds on both platforms, but not at the same magnitude. A rate measured on one platform should be read as specific to that platform.*

The next section asks whether these victims are also exposed to other forms of cybercrime.

Table 13: Victim exposure and password reuse by operating system, with 95 % intervals. The category rows give the percentage of victims who stored credentials for at least one such domain, the last row the percentage who reused at least one password. The three middle columns repeat the macOS percentage as if the macOS victims matched the Windows victims on country, on stored domains per victim, and on both at once. The joint adjustment covers 92.4 % of the Windows victims, the other two 98.2 % and 100 %. The uncovered Windows victims fall in country and volume combinations that hold no macOS victim, leaving no macOS rate to reweight, so the adjusted columns are renormalized over the covered weight.

	macOS				
Measurement	**Observed**	**Country**	**Volume**	**Both**	**Windows**
Domains (median)	45 [42–49]				36 [35–36]
Deviant	49.0 [47.5–50.4]	48.8	46.4	44.1	41.4 [41.2–41.7]
Institutional	78.4 [77.1–79.5]	79.0	77.5	77.6	67.7 [67.5–68.0]
Finance	54.9 [53.4–56.3]	54.7	52.3	50.7	38.0 [37.8–38.2]
Workplace	79.5 [78.3–80.7]	79.0	78.9	76.8	65.7 [65.5–66.0]
Direct IP address	37.8 [36.4–39.2]	39.8	35.3	35.3	27.4 [27.2–27.6]
Internal TLD	5.7 [5.0–6.4]	5.7	5.1	4.6	2.9 [2.8–2.9]
Reused a password	84.9 [83.9–86.0]	85.6	85.0	85.0	89.1 [88.9–89.3]

6. Revictimization

An infostealer infection is rarely a victim's only security problem. To address RQ3, we examine whether victims have also fallen for phishing, what their passwords reveal about their cyber hygiene, and whether organizations in our dataset later appear as ransomware victims.

6.1. Revictimization through phishing

Method: We identify victims who have authenticated to phishing sites. Suspicious TLDs such as `.shop`, `.top`, and `.xyz` accounted for roughly 37 % of cybercrime domains reported between September 2023 and August 2024 [57], so we query VirusTotal about the domains with these TLDs in our dataset and add the phishing domains the Anti-Phishing Working Group (APWG) published for December 2024 and January 2025. A domain counts as phishing if at least one VirusTotal engine flagged it as malicious or if it appears in the APWG feed. Both labels describe a domain as seen at or after our collection, and the logs do not record when a credential was saved, so we count victims who stored credentials for domains labelled as phishing rather than victims phished at that moment. Covering three TLDs and two months of APWG reports, the result is a lower bound.

Results: The set comprises 20,597 domains (11,881 `.xyz`, 5,767 `.top`, and 2,949 `.shop`). VirusTotal had scanned almost all of them (only 73 were not), and 465 carried at least one malicious detection. We find that 1,037 victims disclosed credentials to such fraudulent websites, most of them reported for phishing, and 143 appear in the APWG set. Four victims appear in both, giving 1,176 distinct phishing victims.

Takeaway 11. *Infostealer victims are revictimized through other fraud channels: at least 1,176 had separately disclosed credentials to known phishing sites.*

6.2. Digital hygiene

Good digital hygiene means applying least privilege, separating work from personal activity, using strong and unique

passwords for every service, and keeping the operating system and applications patched.

Method: We measure credential hygiene directly from the passwords and usernames stored in each victim's logs. For every victim we count the stored passwords and usernames, how many are distinct and how many are unique, and whether a username is reused as a password. Distinct counts the different values a victim stored, so a password saved three times contributes one, while unique counts only the values stored exactly once, so that same password contributes none. We use unique in two senses and label every figure below with the one it follows: within-victim unique means a value that occurs exactly once in that victim's own logs, and dataset-wide unique means a value that occurs exactly once across all victims pooled together. We then aggregate these counts across all victims and compare the resulting within-victim rates against prior measurements of user-chosen credentials, which are also reported per user.

Results: Victims rarely meet these standards, starting with their passwords. Our dataset contains a total of 28,026,689 passwords, of which only 1,638,018 (5.84 %) are dataset-wide unique. We find that 88.99 % (n = 151,547 of 170,298) of victims reuse passwords and 86.93 % (n = 148,036 of 170,298) reuse usernames. Additionally, 41.13 % (n = 70,050 of 170,298) of victims use their usernames as passwords.

The average victim has 164.57 password entries. Of these, only 18.06 % (n = 29.72 of 164.57) are distinct, while the remaining 81.94 % (n = 134.85 of 164.57) are repetitions. Furthermore, only 7.41 % (n = 12.20 of 164.57) are within-victim unique, indicating that even among distinct passwords, many are reused. The most common password is reused 43.30 times on average.

Similarly, the average victim has 162.20 usernames, of which 19.43 % (n = 31.52 of 162.20) are distinct and 8.07 % (n = 13.09 of 162.20) are within-victim unique, while the remaining 80.56 % (n = 130.67 of 162.20) are duplicates. The most common username is reused 38.95 times on average.

These observations are consistent with prior work [58], which also finds that users rely on a small set of credentials reused across many accounts, reporting similarly low proportions of within-victim unique passwords and usernames. In particular, they report that only about 4.45 % of passwords and 6.24 % of usernames are unique per user, compared to 7.41 % and 8.07 % in our dataset. Both sides of this comparison use the within-victim definition; the dataset-wide figure above is not comparable to it. Moreover, victims who stored credentials on phishing-flagged domains are a negligible share of the dataset (1,176 of 170,298), so credentials saved on such sites cannot materially affect these reuse rates.

Figure 10 shows the repetition rate of usernames and passwords for victims with 50 or more credentials. On average, 86 % of usernames and 87 % of passwords are reused. Across the whole dataset, the single most common password accounts for 667,386 entries (2.38 % of all passwords).

As shown in Figure 6, victims access work or critical services alongside recreational and even illegal content on the same device, consistent with surveys on remote workers using work devices for personal activities [59, 60], underscoring the need for effective cyberawareness training [61].

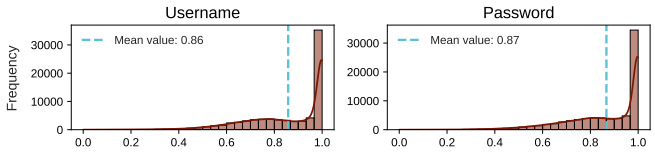


Figure 10: Statistics on credential leakage, filtered to include only victims with 50 or more credentials.

Takeaway 12. *Victims show severe digital hygiene failures:* 88.99 % *reuse passwords, only* 5.84 % *of all passwords are unique, and* 41.13 % *use a username as a password. A single victim's log typically holds both personal accounts and work or critical-service logins, so one compromise exposes both at once.*

6.3. Links to ransomware victims

Beyond exploiting software vulnerabilities, ransomware groups such as LockBit often lure employees into leaking credentials to gain an initial foothold in a target organization. Harvesting credentials from infostealer logs is therefore a plausible shortcut to that foothold, and we measure how far the two victim populations overlap.

Method: We collected all domains with leaked credentials in our dataset and all victims listed in the `Ransomware.live` database [62], keeping only the ransomware victims whose entry included a URL we could match against, so the monthly totals in Table 14 count only the victims we could resolve to a domain. A match requires the domain in the Ransomware.live entry to equal a domain for which our dataset holds credentials, and we inspected every candidate by hand to reject partial string matches. Because initial access, ransomware deployment, and the eventual publication of stolen data can be separated by long and variable gaps, we widen the window and study ransomware victims from October 2024 to the end of May 2025. We report the triaged results in aggregate, counting only whether leaked credentials exist for an organization, not how many.

Results: The existence of leaked credentials for an organization does not imply that the organization will be compromised, as the credentials might not provide elevated access to the system but rather harm the individual victim. For instance, credentials belonging to a bank's or an e-shop's customers most likely harm those customers rather than the organization itself. Nevertheless, the leaked credentials in our dataset are not associated solely with domains that are expected to have many unprivileged users. Some of the matched domains are webmail and remote-access services, where a compromised account can serve an adversary directly, for instance by abusing an employee's mailbox to induce colleagues to open malicious files. As shown in Table 14, leaked credentials appear across all months in the observation window, including months before our January 2025 collection. We note that 54 matches occur in February 2025, the peak month, which also coincides with the highest number of reported ransomware victims (n = 654). A log records when we collected it, not when the credentials were stolen or when they began circulating, so we cannot place a given exposure before or after the

ransomware event it matches. The overlap is therefore evidence of a shared victim population rather than of initial access.

Table 14: Identified ransomware victims.

Month	# Ransomware victims' URLs	Identified Leaked credentials
Oct 2024	238	23
Nov 2024	286	21
Dec 2024	311	43
Jan 2025	369	48
Feb 2025	654	54
Mar 2025	356	31
Apr 2025	139	5
May 2025	228	11

Takeaway 13. *Organizations listed as ransomware victims frequently also appear in infostealer logs as domains with exposed employee credentials. We measure the overlap between the two populations, not initial access, but an overlap this size is reason enough to treat infostealer exposure as a warning sign: reset the affected credentials and enforce multi-factor authentication on email and remote access.*

7. Discussion

The preceding sections show that infostealer infections rarely stand alone. A single compromise exposes work and personal accounts together, most of them protected by a handful of reused passwords, and supplies credentials that resurface in phishing and ransomware campaigns. These findings hold only within the limits of our methods.

7.1. Limitations

Sample bias: This study does not represent a sample of all infostealer infections or of the broader internet population; it is based on criminal actors sharing publicly available logs, collected in January 2025 and covering victim device data from 2024 to 2025. As a result, we underestimate the extent of infostealer attacks and miss very targeted ones. Logs with the highest resale value are the least likely to be given away, so exposure among critical organizations is probably worse than we measure.
Source coverage: Our coverage is uneven by design. The collection plan emphasizes underground forums and open Telegram and Discord channels, which can under-represent closed ecosystems, non-indexed communities, and sources reachable only through different languages or access modalities, a common constraint in Cybersecurity Threat Landscape (CTL) style production [63].
Third-party sandbox output: The family characterization in Section 4 rests on sandbox reports published by external services. We did not control the execution environment, we did not validate the family labels or the ATT&CK mapping ourselves, and we cannot determine how many samples failed to produce a report, so the counts in Table 4 are of labelled samples rather than of successful executions.
Unknown infection vector: Victims heavily used online gaming services, which suggests a link to the infection vector, but we cannot verify it. Our behavioral findings therefore describe online gaming consumers more than the general population.
Authenticated services only: We study only the services where a victim authenticated with credentials, so we do not study the full browsing history and miss any site visited without logging in.
Unrecognized services: Many services cannot be identified from their URLs alone, so for those entries we often cannot determine which account or service a victim's compromised credentials belong to.
Asymmetric deduplication: We distinguish Windows victims by machine identifier and macOS victims by IP address, so a shared address merges several macOS devices into a single record. This undercounts macOS victims and inflates their per-victim rates. We bound both effects using the Windows victims, for whom we hold both identifiers: deduplicating a random Windows subsample the size and country mix of the macOS population by address alone hides 0.9 % [0.6–1.2] of its devices and leaves 0.6 % [0.4–0.8] of its records holding more than one device, over 200 draws with 95 % percentile intervals. The 4,523 macOS records therefore stand for roughly 4,563 devices [4,551–4,577]. Standardizing on the number of stored domains absorbs much of the remaining effect, so the macOS rates in Table 13 are inflated by well under one percent.

7.2. Lessons learned

A compromised host exposes passwords, session tokens, and cryptographic keys alike, so controls built around secrets and signatures no longer suffice on their own; protection has to move toward hardware-bound authentication and behavior-based detection.

Lesson 1. *Session hijacking via cookie theft enables attackers to bypass multi-factor authentication. Passkeys and other FIDO2-based mechanisms strengthen authentication but do not protect against session replay attacks: an adversary who exfiltrates authenticated session artifacts (e.g., infostealer malware copying web browser cookies) can reuse them to impersonate the user. Mitigating this class of attacks requires the adoption of device-bound session mechanisms: Chrome (Windows) is rolling out Device Bound Session Credentials (DBSC)[2], where session tokens are cryptographically bound to a hardware-backed key (e.g., Trusted Platform Module [TPM]). Protection against session hijacking requires the use of short-lived hardware-bound tokens: the (web) server must periodically ask the (web browser) client to provide cryptographic hardware-backed verification during session use.*

By collecting private keys, certificates, and VPN configurations, infostealers hand attackers access to organizations' internal networks. Because they harvest credentials across so many critical services, password complexity policies, however necessary, cannot protect user accounts on their own.

[2] https://developer.chrome.com/docs/web-platform/device-bound-session-credentials

Lesson 2. *Endpoint protection mechanisms must refine their strategies to better protect hosts from data exfiltration. Table 4 shows that all seven families read data from the local system (T1005) and credentials from files (T1552.001, or its superseded identifier T1081), and query system information (T1082, T1012), as core TTPs. Monitoring access to well-known browser files (e.g., Chrome's `Login Data` and `Cookies` SQLite databases, Firefox's `logins.json`) during runtime would create a high-fidelity detection signal applicable across all studied families, enabling endpoint protection to block exfiltration even when the malware binary is novel or obfuscated.*

The same signal extends beyond browser files to the encryption keys, VPN settings, and cryptocurrency wallets that infostealers harvest. Defenses also cannot assume a single target platform.

Lesson 3. *The dataset contains 4,523 macOS infections. This finding challenges the common perception that macOS systems face negligible malware risk and underscores that macOS is not immune to infostealers.*

The macOS victims differ from the Windows majority in what they expose rather than in how carelessly they behave, holding more institutional, financial and workplace credentials, twice the rate of internal hosts, and slightly fewer reused passwords (Section 5.10). That profile fits a work device better than a personal one, though our records do not say who owns the machine. Establishing whether macOS victims are disproportionately reached through employer-issued hardware is worth doing, because a managed fleet can be defended centrally and a personal laptop holding work credentials cannot.

8. Conclusion

To our knowledge, this work presents the first ethically guided, victim-centered analysis at this scale of openly shared logs from modern infostealer malware, covering 170,298 distinct victims worldwide compromised in 2024–2025. By applying data minimization and privacy-preserving anonymization, we draw insights without exposing direct personally identifiable information, recoverable credentials, or live access tokens.

Our findings demonstrate that infostealers constitute a pervasive and significant threat to both individuals and organizations. The dataset reveals broad exposure across sensitive sectors, including government, military, law enforcement, and critical infrastructure, underscoring the national security implications of infostealer compromise. Compromised credentials span high-value targets such as academic institutions (all eight Ivy League universities), international organizations (`interpol.int`, n = 2), and government agencies (`dhs.gov`, n = 42).

Our analysis highlights the central role of human factors: widespread credential reuse (88.99 % of victims), poor digital hygiene, and susceptibility to revictimization through phishing and ransomware. These findings reinforce that technical defenses alone are insufficient without user-centered security practices, awareness training, and periodic hardware-backed authentication through short-lived session tokens.

Beyond the empirical findings, this work demonstrates that illicit cybercrime datasets can be transformed into privacy-preserving research artifacts suitable for reproducible scientific analysis. We share the anonymized dataset and the complete analysis code under restricted access, granted on request for academic use (Data availability), and encourage the security community to build upon them. In particular, future work can examine how victim behavior relates to their exposure.

CRediT authorship contribution statement

Contributor Roles Taxonomy (CRediT) statement of authorship contribution.

Contributions	A.P.	J.N.	D.A.	S.M.	F.C.	M.N.	J.I.	J.S.	C.P.	G.S.
Conceptualization	●	●	●	○	○	●	●	○	●	●
Data curation	●	●	○	●	○	○	○	○	●	○
Formal Analysis	●	●	○	●	○	○	○	○	●	○
Funding acquisition	○	●	●	○	●	●	○	○	●	●
Investigation	●	●	●	●	●	○	●	○	●	●
Methodology	●	●	●	○	●	●	●	○	●	●
Project administration	○	●	●	○	●	○	●	○	●	●
Resources	○	●	●	○	○	●	○	○	●	●
Software	●	●	○	●	○	○	○	○	●	○
Supervision	○	●	○	○	○	○	○	○	●	●
Validation	●	○	○	○	○	○	○	○	○	○
Visualization	●	●	○	●	○	○	○	○	●	○
Writing—original draft	●	●	●	○	●	○	●	○	●	●
Writing—review & editing	●	●	●	●	●	●	○	●	●	●

Declaration of competing interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Acknowledgments

This work was supported by the European Commission under the Horizon Europe funding programme, as part of the project SafeHorizon (Grant Agreement number 101168562). This work was partially supported by Ministerio de Ciencia, Innovación y Universidades, Gobierno de España (Agencia Estatal de Investigación, Fondo Europeo de Desarrollo Regional –FEDER–, European Union) under the research grant PID2021-127409OB-C33 CONDOR, and by AGAUR with the project ASCLEPIUS (2021SGR-00111), and by Comunidad Autónoma de Madrid, CIRMA-CAM Project (TEC-2024/COM-404). Fran Casino was supported by the Spanish Ministry of Science and Innovation under the "Ramón y Cajal" programme (RYC2023-044857-I).

The authors would like to thank Sara Degli-Esposti for her valuable feedback and support.

Views and opinions expressed are however those of the author(s) only and do not necessarily reflect those of the European Union. Neither the European Union nor the granting authority can be held responsible for them.

The funding sources had no involvement in the study design; in the collection, analysis, and interpretation of data; in the writing of the report; or in the decision to submit the article for publication.

Declaration of generative AI and AI-assisted technologies in the manuscript preparation process

During the preparation of this work the authors used QuillBot and Claude Opus in order to check grammar and proofread the text, and ChatGPT in order to improve the Python analysis code and LaTeX markup. No AI-generated text was included in the manuscript; the authors wrote all the text. After using these tools/services, the authors reviewed and edited the content as needed and take full responsibility for the content of the published article.

Data availability

In accordance with the data and open-science policy of the journal, we provide the artifacts necessary to replicate our calculations, analyses, tables, and figures. The dataset of infostealer malware victims (processed and anonymized) and our analysis code are deposited on Zenodo under restricted access [64]. Access is granted on request to researchers who state an academic purpose, following recent measurement studies that share sensitive data on the same terms [65, 66, 67]. A request states the applicant's institutional affiliation and academic role and describes the intended research use. Requesting access constitutes acceptance of the terms of use, which forbid attempts to re-identify the victims, redistribution of the data to third parties, and any operational or commercial use of the records. The corresponding author reviews each request against those terms and replies within six weeks, usually sooner. The deposit contains: (i) the processed infostealer victim dataset with direct personally identifiable information removed or replaced, (ii) the CSV files containing the phishing dataset, (iii) the complete analysis scripts, and (iv) a detailed `README.md` documenting the full workflow, including data preparation, analysis steps, and figure generation.

The documentation enables researchers granted access to fully reproduce our results and build upon our dataset for future studies, while adhering to all legal and ethical constraints.

References

[1] Verizon, 2025 data breach investigations report, https://www.verizon.com/business/resources/T73d/reports/2025-dbir-data-breach-investigations-report.pdf, accessed: 2025-08-22 (2025).

[2] CrowdStrike, CrowdStrike 2026 Global Threat Report, https://www.crowdstrike.com/en-us/global-threat-report/, accessed: 2026-04-14 (2026).

[3] IBM Security, X-force threat intelligence index 2024, IBM (2024).
URL https://www.ibm.com/think/x-force/2024-x-force-threat-intelligence-index

[4] D. Geer, The Infamous Infostealers: How are cybercriminals getting their hands on so much data?, Communications of the ACM News, https://cacm.acm.org/news/the-infamous-infostealer/ (2025).

[5] C. Krebs, National Public Data Published Its Own Passwords, https://krebsonsecurity.com/2024/08/national-public-data-published-its-own-passwords/ (2024).

[6] J. Casal, New Findings on the National Public Data Breach: Poor Security Measures and the Role of Infostealer Malware as a Possible Vector of Attack, https://securityboulevard.com/2024/09/new-findings-on-the-national-public-data-breach-poor-security-measures-and-the-role-of-infostealer-malware-as-a-possible-vector-of-attack/ (2024).

[7] C. Patsakis, D. Arroyo, F. Casino, The malware as a service ecosystem, in: Malware: Handbook of Prevention and Detection, Springer, 2024, pp. 371–394.

[8] J. Nurmi, M. S. Niemelä, B. B. Brumley, Malware finances and operations: a data-driven study of the value chain for infections and compromised access, in: Proceedings of the 18th International Conference on Availability, Reliability and Security, ARES 2023, Benevento, Italy, 29 August 2023- 1 September 2023, ACM, 2023, pp. 108:1–108:12.

[9] A. Avgetidis, O. Alrawi, K. Valakuzhy, C. Lever, P. Burbage, A. D. Keromytis, F. Monrose, M. Antonakakis, Beyond The Gates: An empirical analysis of HTTP-managed password stealers and operators, in: 32nd USENIX Security Symposium, USENIX Security 2023, Anaheim, CA, USA, August 9-11, 2023, USENIX Association, 2023, pp. 5307–5324.

[10] T. Marjanov, A. Hutchings, Sok: Digging into the digital underworld of stolen data markets, in: IEEE Symposium on Security and Privacy, SP 2025, San Francisco, CA, USA, May 12-15, 2025, IEEE, 2025, pp. 1–18.

[11] N. Pantazopoulos, S. Misraa, Technical analysis of Rhadamanthys obfuscation techniques, https://www.zscaler.com/blogs/security-research/technical-analysis-rhadamanthys-obfuscation-techniques, accessed: 2025-08-20 (2023).

[12] M. A. Khader, Unmasking the evolving threat: A deep dive into the latest version of lumma infostealer with code flow obfuscation, https://www.trellix.com/en-au/blogs/research/lumma-stealer-analysis/, accessed: 2025-08-24 (2025).

[13] A. Tavares, Exfiltration over Telegram bots: Skidding infostealer logs, https://www.bitsight.com/blog/exfiltration-over-telegram-bots-skidding-infostealer-logs, accessed: 2026-09-01 (2024).

[14] V. Koutsokostas, N. Lykousas, T. Apostolopoulos, G. Orazi, A. Ghosal, F. Casino, M. Conti, C. Patsakis, Invoice #31415 attached: Automated analysis of malicious Microsoft office documents, Comput. Secur. 114 (2022) 102582.

[15] J. D. Cruz, TikTok videos promise pirated apps, deliver Vidar and StealC infostealers instead, https://www.trendmicro.com/en_us/research/25/e/tiktok-videos-infostealers.html, accessed: 2025-05-27 (2025).

[16] v4ensics, Lumma Stealer – a tale that starts with a fake CAPTCHA, https://v4ensics.gr/lumma-stealer-a-tale-that-starts-with-a-fake-captcha/, accessed: 2025-08-20 (2025).

[17] Cybereason Security Services Team, Your Data Is Under New Lummanagement: The Rise of LummaStealer, https://www.cybereason.com/blog/threat-analysis-rise-of-lummastealer, accessed: 2025-08-08 (2024).

[18] M. Neagu, RedLine Stealer analysis, https://www.bitdefender.com/files/News/CaseStudies/study/415/Bitdefender-PR-Whitepaper-RedLine-creat6109-en-EN.pdf, accessed: 2025-08-22 (2022).

[19] New Jersey Cybersecurity & Communications Integration Cell (NJCCIC), Browser extensions and malicious downloads install infostealers, https://www.cyber.nj.gov/Home/Components/News/News/1657/214, accessed: 2025-08-08 (2025).

[20] S. Masada, Disrupting Lumma Stealer: Microsoft leads global action against favored cybercrime tool, https://blogs.microsoft.com/on-the-issues/2025/05/21/microsoft-leads-global-action-against-favored-cybercrime-tool/, accesssed: 2025-08-20 (2025).

[21] B. Toulas, 'Russian Market' emerges as a go-to shop for stolen credentials, https://www.bleepingcomputer.com/news/security/russian-market-emerges-as-a-go-to-shop-for-stolen-credentials, accessed: 2025-08-20 (2025).

[22] A. Buescher, F. Leder, T. Siebert, Banksafe information stealer detection inside the web browser, in: Recent Advances in Intrusion Detection - 14th International Symposium, RAID 2011, Springer, 2011, pp. 262–280. doi:10.1007/978-3-642-23644-0_14.

[23] Á. Bustos-Tabernero, D. L. Sánchez, A. G. Arrieta, Detection of infostealer variants through graph neural networks, in: Distributed Computing and Artificial Intelligence, 20th International Conference, DCAI 2023, Springer, 2023, pp. 65–73. doi:10.1007/978-3-031-38333-5_7.

[24] B. Al-Sada, A. Sadighian, G. Oligeri, MITRE ATT&CK: State of the art and way forward, ACM Computing Surveys 57 (1) (2025) 12:1–12:37. doi:10.1145/3687300.

[25] D. R. Thomas, S. Pastrana, A. Hutchings, R. Clayton, A. R. Beresford, Ethical issues in research using datasets of illicit origin, in: Proceedings of the 2017 Internet Measurement Conference, IMC 2017, London, United Kingdom, November 1-3, 2017, ACM, 2017, pp. 445–462.

[26] T. Kohno, Y. Acar, W. Loh, Ethical frameworks and computer security trolley problems: Foundations for conversations, in: 32nd USENIX Security Symposium (USENIX Security 23), USENIX Association, Anaheim, CA, 2023, pp. 5145–5162.

[27] Abuse.ch and Spamhaus, MalwareBazaar, https://bazaar.abuse.ch/, accessed: 2025-08-08 (2025).

[28] Recorded Future, Triage, https://tria.ge/, accessed: 2025-08-24 (2025).

[29] MITRE, MITRE ATT&CK, https://attack.mitre.org, accessed: 2025-08-20 (2025).

[30] Spamhaus' passive DNS API, Spamhaus, https://www.spamhaus.com/data-access/passive-dns-api/, accessed: 2025-11-16 (2025).

[31] D. Plohmann, K. Yakdan, M. Klatt, J. Bader, E. Gerhards-Padilla, A comprehensive measurement study of domain generating malware, in: 25th USENIX Security Symposium, USENIX Security 16, Austin, TX, USA, August 10-12, 2016, USENIX Association, 2016, pp. 263–278.

[32] F. Casino, N. Lykousas, I. Homoliak, C. Patsakis, J. C. Hernandez-Castro, Intercepting Hail Hydra: Real-time detection of algorithmically generated domains, Journal of Network and Computer Applications 190 (2021) 103135.

[33] Forbes, Google Confirms New Gmail Security Boost For 2.5 Billion Users, https://www.forbes.com/sites/daveywinder/2024/10/08/google-confirms-new-gmail-security--boost-for-25-billion-users/, accessed: 2025-08-25 (2024).

[34] Backlinko Team, Facebook user & growth statistics, https://backlinko.com/facebook-users, accessed: 2025-05-13 (2025).

[35] Backlinko Team, Instagram statistics: Key demographic and user numbers, https://backlinko.com/instagram-users, accessed: 2025-05-13 (2025).

[36] D. Curry, Discord revenue and usage statistics (2025), https://www.businessofapps.com/data/discord-statistics/, accessed: 2025-05-13 (2025).

[37] Backlinko Team, Roblox user and growth stats you need to know, https://backlinko.com/roblox-users, accessed: 2025-05-13 (2025).

[38] S. Singh, Netflix subscribers statistics 2025 (by country & demographics), https://www.demandsage.com/netflix-subscribers/, accessed: 2025-05-13 (2025).

[39] A. Mosby, Amazon statistics 2025 (number of users & revenue, https://www.yaguara.co/amazon-statistics/, accessed: 2025-05-13 (2025).

[40] N. Kumar, Steam statistics 2025 – users, revenue, & market share, https://www.demandsage.com/steam-statistics/, accessed: 2025-05-13 (2025).

[41] Backlinko Team, X (Twitter) statistics: How many people use X? (updated April 2025), https://backlinko.com/twitter-users, accessed: 2025-05-13 (2025).

[42] Chargeflow, PayPal statistics and facts 2025 (updated), https://www.chargeflow.io/blog/paypal-statistics-facts, accessed: 2025-05-13 (2025).

[43] Backlinko Team, Spotify user stats (updated February 2025), https://backlinko.com/spotify-users, accessed: 2025-05-13 (2025).

[44] G. McGraw, Exploiting online games, in: 16th USENIX Security Symposium (USENIX Security 07), USENIX Association, Boston, MA, 2007.
URL https://www.usenix.org/conference/16th-usenix-security-symposium/exploiting-online-games

[45] I. Vakilinia, From cracks to crooks: Youtube as a vector for malware distribution, in: 2026 14th International Symposium on Digital Forensics and Security (ISDFS), 2026, pp. 1–6. doi:10.1109/ISDFS69419.2026.11459119.

[46] DataReportal, Digital 2025: Global overview report, https://datareportal.com/reports/digital-2025-global-overview-report, accessed: 2025-05-12 (January 2025).

[47] Quentin Bourgue and Sekoia TDR, Overview of the russian-speaking infostealer ecosystem: the distribution, https://blog.sekoia.io/overview-of-the-russian-speaking-infostealer-ecosystem-the-distribution/ (2023).

[48] Check Point, Lumma malware: Unmasking the stealthy infostealer, https://www.checkpoint.com/cyber-hub/threat-prevention/what-is-malware/lumma-malware/ (2025).

[49] S. Masada, Disrupting Lumma Stealer: Microsoft leads global action against favored cybercrime tool, https://blogs.microsoft.com/on-the-issues/2025/05/21/microsoft-leads-global-action-against-favored-cybercrime-tool/ (2025).

[50] endoflife.date, Microsoft Windows End-of-life (EOL) and support information, https://endoflife.date/windows, accessed: 2025-08-08 (2024).

[51] Cisco Talos Intelligence Center, Cisco Talos URL Reputation Lookup, https://www.talosintelligence.com/reputation_center/, accessed: 2025-08-20 (2025).

[52] A. Mous, Ingram Micro struck by ransomware attack, causing ongoing system outage, https://cybernews.com/security/ingram-micro-struck-by-ransomware/, accessed: 2025-08-08 (2025).

[53] Federal Deposit Insurance Corporation, BankFind Suite: API Documentation, https://banks.data.fdic.gov/docs/, accessed: 2025-08-08 (2025).

[54] European Banking Association, EBA Members, https://www.abe-eba.eu/about-eba/eba-members/, accessed: 2025-08-08 (2025).

[55] Directive (eu) 2015/2366 of the european parliament and of the council of 25 november 2015 on payment services in the internal market, https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=celex%3A32015L2366 (2015).

[56] Privacy Tools, Top 4: Best VPN for internet privacy & security in 2025 - best VPN services, https://www.privacytools.io/privacy-vpn, accessed: 2025-08-08 (2025).

[57] Interisle Consulting Group, Cybercrime supply chain 2024: Measurements and assessments of cyber attack resources and where criminals acquire them, https://interisle.net/insights/cybercrimesupplychain2024, accessed: 2025-08-20 (2024).

[58] Y. Bang, D. Lee, Y. Bae, J. Ahn, Improving information security management: An analysis of id-password usage and a new login vulnerability measure, Int. J. Inf. Manag. 32 (5) (2012) 409–418. doi:10.1016/J.IJINFOMGT.2012.01.001.
URL https://doi.org/10.1016/j.ijinfomgt.2012.01.001

[59] ESET, Brits turn blind eye to cybersecurity risks with 90% using work laptops for personal use, https://www.eset.com/uk/about/newsroom/press-releases/brits-turn-blind-eye-to-cybersecurity-risks-with-90-using-work-laptops-for-personal-use/, accessed: 2025-08-08 (2024).

[60] J. R. C. Nurse, N. Williams, E. Collins, N. Panteli, J. M. Blythe, B. Koppelman, Remote working pre- and post-covid-19: An analysis of new threats and risks to security and privacy, in: HCI International 2021 - Posters - 23rd HCI International Conference, HCII 2021, Virtual Event, July 24-29, 2021, Proceedings, Part III, Vol. 1421 of Communications in Computer and Information Science, Springer, 2021, pp. 583–590.

[61] J. K. Nwankpa, P. M. Datta, Remote vigilance: The roles of cyber awareness and cybersecurity policies among remote workers, Computers & Security 130 (2023) 103266.

[62] J. Mousqueton, Ransomware.live: Ransomware Leak-Site Monitoring, https://www.ransomware.live/, accessed: 2025-08-08 (2025).

[63] ENISA, ENISA cybersecurity threat landscape methodology (updated august 2025), Tech. rep., European Union Agency for Cybersecurity, Athens, Greece, accessed: 2025-08-25 (2025). doi:10.2824/1888892.

URL https://www.enisa.europa.eu/publications/enisa-cybersecurity-threat-landscape-methodology

[64] A. Paju, J. Nurmi, D. Arroyo, S. Chica Manjarrez, F. Casino, M. Niemelä, J. Itkonen, J. Scanlan, C. Patsakis, G. Smaragdakis, A Data-Driven Analysis of Infostealer Malware Victims, Zenodo dataset, restricted access (2026). doi:10.5281/zenodo.22655144.
URL https://doi.org/10.5281/zenodo.22655144

[65] R. Yaben, M. Anguita, E. Vasilomanolakis, Measuring what matters: Revisiting internet exposure of OT networks, Computers & Security 167 (2026) 104911. doi:10.1016/j.cose.2026.104911.

[66] M. Szakály, S. Köhler, I. Martinovic, Current Affairs: A Security Measurement Study of CCS EV Charging Deployments, in: 34th USENIX Security Symposium, USENIX Security 2025, USENIX Association, 2025, pp. 7997–8015.

[67] T. Marjanov, T. Tsuchiya, J. Hughes, N. Christin, A. Hutchings, Stayin' Alive: How Global Stolen Data Markets Thrive on Telegram, in: 35th USENIX Security Symposium, USENIX Security 2026, USENIX Association, 2026.

[68] R. Aghili, H. Li, F. Khomh, Protecting Privacy in Software Logs: What Should Be Anonymized?, Proceedings of the ACM on Software Engineering 2 (FSE) (2025) 1317–1338. doi:10.1145/3715779.

[69] E. Kenneally, D. Dittrich, The menlo reportethical principles guiding information and communication technology research, https://www.dhs.gov/sites/default/files/publications/CSD-MenloPrinciplesCORE-20120803_1.pdf, accessed: 2025-08-22 (2022).

Appendix

A. Ethical considerations

The SafeHorizon project partner collected the raw data files in January 2025 as part of monitoring infostealer malware operations. The partner's operational collection was conducted under its own legal and compliance framework for threat-intelligence operations. The SafeHorizon project applied for ethical approval for processing this data into a research dataset shared across the project. The Ethics Advisory Board of the SafeHorizon project (101168562) formally approved the research methodologies and data processing protocols for the infostealer malware data on 26 August 2025. They reviewed and endorsed the approach to data collection and dissemination, including the release of the anonymized dataset on Zenodo for scholarly use, and carefully considered the ethical implications of conducting research without direct consent from the affected individuals, emphasizing strict adherence to data minimization principles.

Data minimization and anonymization. Given that the dataset of infostealer logs analyzed herein originated from illicit activities, we followed the guidance of Thomas et al. [25] and recent discussions in the security ethics literature [26] to take measures based on the analysis of the potential harms and benefits of this research. To minimize potential harms to victims and prevent re-identification, we applied the data minimization principle, as defined in the EU General Data Protection Regulation. An example of anonymized victim data is included as a JSON snapshot in Listing 1 in Appendix D. Personally Identifiable Information, such as IP addresses, machine identifiers, usernames, and passwords, was replaced with a salted hash during data preprocessing. Further procedures were applied to reduce the risk of accidentally encountering additional PII in the information leaked from the compromised services. For example, to avoid having usernames corresponding to real family names, all were replaced.

Removal of raw data. To protect the victims, we permanently removed the original raw data after processing it into a research database that we can share with the research community. Releasing the anonymized dataset and our analysis code enables the community to reproduce our findings and study how to protect users and secure systems against infostealers, without processing the original sensitive logs. This keeps our work on an ethically constructed dataset with a balanced risk-benefit ratio.

Controlled access. The dataset is released through Zenodo under restricted access, granted on request to researchers who state an academic purpose and accept a data use agreement. Privacy in software logs is still an underexplored problem with no settled definition of what counts as sensitive, and combinations of quasi-identifiers such as operating system, language, VPN status, and autonomous system can support re-identification even after direct identifiers are removed [68]. We therefore treat research data as open as possible and as closed as necessary, and pair the field-level generalization in Table 3 with access control rather than relying on either alone. Recent measurement studies that work with sensitive network and infrastructure data share it on the same terms [65, 66, 67].

Respect for persons. From a deontological perspective, victims shall be protected from further harm. We honored this duty through data minimization, anonymization, removal of residual identifiers, and exclusion of any content that could be operationally misused. Tangible harms such as re-compromise were mitigated through anonymization, salted hashing, and avoiding host contact (e.g., service status was assessed via publicly available tools such as Shodan). Residual re-identification risk is limited to potential inferences from external datasets, which we consider unlikely given applied protections. Following recommendations originating from both consequentialist and deontological approaches [26], we prioritize the defense of the victims through the deontological duty to privacy protection. In practice, we reverse-engineered infostealer malware to identify exfiltration endpoints and collected samples without contacting live victims, so the analysis never required handling victims' PII directly. The released dataset does not store recoverable credential material, private keys, or live access tokens. This minimizes the risk that researchers are exposed to information that could

be exploited to target or attack a person or an organization.

Researcher well-being. The team was not exposed to harmful or illicit material: web-content categories, including highly sensitive ones such as child sexual abuse material, were assigned automatically by the third-party Cisco Talos URL Reputation API from URL strings, never by human inspection of content. Access to sensitive data was restricted, encrypted, and limited to necessary analysis.

Responsible disclosure. During the course of this research, we identified active illegal websites, malware distribution infrastructure, and other security threats. We reported these findings to the appropriate authorities and trusted operational partners. Through the SafeHorizon project, partners coordinate responses with national Computer Emergency Response Teams (CERTs), law enforcement agencies, and other relevant stakeholders to support the mitigation. Individual victims were not contacted directly, as the released research dataset contains only anonymized information and does not permit re-identification.

Risk-benefit analysis. Following the Menlo Report [69] and consequentialist reasoning, we argue that the benefits of understanding modern infostealer operations, exposure patterns, and hygiene failures, summarized in the lessons learned section of this paper, outweigh the residual privacy risk. Specific stakeholders who can benefit from our research include: (i) individuals whose devices were compromised, who can learn how to better protect themselves; (ii) organizations whose members had their credentials compromised and should revise their security awareness training and procedures; (iii) law enforcement agents and incident response teams who can identify groups of users or services more at risk and take measures to prevent future harm; and (iv) security practitioners and scholars who can replicate the study advancing further the debate about the trade-off between data minimization and data usability. Finally, we believe that this paper does not disclose recoverable credentials, live access tokens, or operational details that would enable malevolent actions.

B. Victim statistics

Table B.1 gives the most common (a) languages and (b) autonomous systems of the infostealer victims. The "Other" and "Aggregated" rows hold the values that the generalization described in Section 3.1 replaced, so the named rows do not cover every victim.

Table B.1: Victim statistics.

(a) Victims' languages.

Language	Count
en	86,495
es	21,993
pt	15,789
fr	7,309
N/A	6,293
tr	4,903
ar	3,944
th	3,452
Other	2,142
pl	2,100

(b) ASN used by the victims.

ASN	Count
Aggregated	61,385
Reliance Jio Infocomm Limited	5,345
TE Data	3,739
PT Telekomunikasi Indonesia	3,045
Bharti Airtel Ltd. Telemedia	2,885
VNPT Corp	2,811
Viettel Group	2,597
COMCAST-7922	2,346
Telecom Algeria	2,122
Philippine telecom PLDT, Inc.	2,093
Claro NXT Telecomunicacoes	1,896

C. Infostealer offerings

Figure C.1 shows an infostealer operator's offerings on Telegram, using discounts and tiered pricing to attract customers with different budgets.

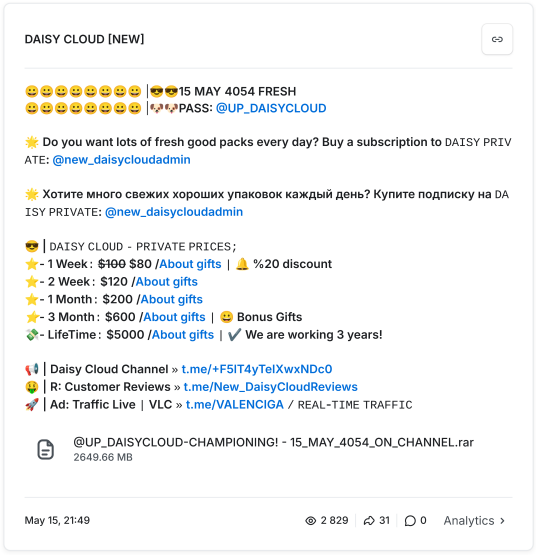


Figure C.1: Infostealer malware logs offerings.

D. Example of infostealer data

Listing 1: A victim's profile from our dataset (0001021.json)

```
{
    "timestamp": "2024-12-30",
    "ip_address": "d17f353166",
    "ip_location": "US",
    "ip_asn": "ASN: 212238, ORG: Datacamp Limited",
    "is_vpn": "VPN",
    "location": "",
    "country": "US",
    "os": "Windows 11 Home",
    "machineid": "57d7535e8a",
    "language": "en",
    "keyboard_layouts": [],
    "passwords": ["a809434c42", "8c32f0d2f0", ...],
    "usernames": ["b8f2935589", "b8f2935589", ...],
    "urls": [
        "https://spotify.com",
        "https://uploadhaven.com",
        ...
    ],
    "onion_domain_names": [],
    "urls_count": 276,
    ...
}
```

Listing 1 is an example of anonymized victim data that is included as a JSON snapshot in our dataset. Table 3 gives the treatment applied to each field.

As described in Appendix A, the `ip_address`, `machineid`, `usernames`, and `passwords` fields are all replaced with salted hashes (Section 3.1). The URLs field retains the registered domain of each service the victim authenticated to, including the critical-infrastructure domains reported in Table 10.

E. Infostealer C2 server infrastructure

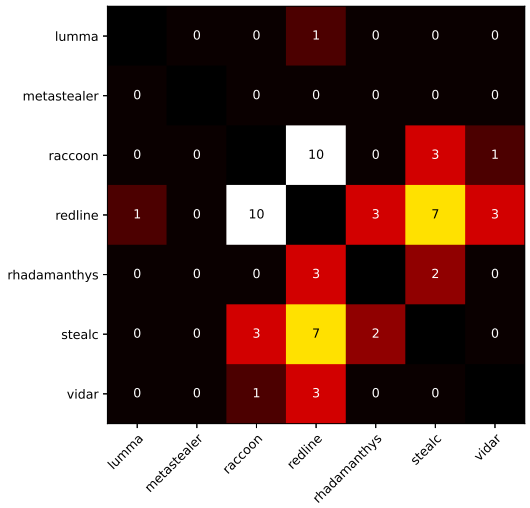


Figure E.1: Common infrastructure used as C2 servers by different infostealers.

Figure E.1 plots the C2 infrastructure shared between infostealers over our study period. Non-zero values, most notably between RedLine and Raccoon (10 shared IPs) and RedLine and StealC (7 shared IPs), show infrastructure overlap between families (Section 4).